BORRADOR DE VALIDACIÓN TÉCNICA — no sustituye al documento institucional

[Logo oficial UMG — pendiente: lo integra el equipo con la carátula institucional]

UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

Maestría en Seguridad Informática

Curso: Seguridad en Aplicaciones

Laboratorio de Seguridad de Aplicaciones sobre OWASP Juice Shop

Fase 6: Operaciones, Monitoreo y Ciberseguridad

Integrantes:

Molina Pérez, Juan Carlos

Sánchez Flores, Juan Walter Ernesto

García Gonzalez, Leopoldo Emanuel

Cambara Castillo, Vanessa Odeth

Catedrático: Ing. Matthew Alexander Seigne Samayoa

Guatemala, noviembre de 2026

Índice

Introducción....3

Objetivos....3

1. Estrategia de Mitigación y Ciberseguridad....5

1.1 Arquitectura operativa y defensa en profundidad....5

1.2 Controles compensatorios por riesgo....6

1.3 WAF: reglas para el OWASP Top 10:2025....7

1.4 RASP: detección y bloqueo en tiempo de ejecución....9

1.5 Monitoreo de APIs: heurística de comportamiento anómalo....12

1.6 SIEM: centralización y correlación de logs....12

1.7 Validación integral de los controles....15

2. Tratamiento Formal del Riesgo....17

2.1 Método de valoración....17

2.2 Opciones de tratamiento....18

2.3 Categorización del riesgo por tipo e impacto....18

2.4 Matriz de decisiones y plan de tratamiento....19

2.5 Justificación del riesgo residual....21

2.6 Matriz de calor: probabilidad frente a impacto....22

2.7 Lectura del riesgo residual....25

Limitaciones y pendientes....27

Conclusiones....27

Referencias....29

Anexos....30

Introducción

Este documento presenta la Fase 6 del laboratorio de Seguridad de Aplicaciones sobre OWASP Juice Shop 20.3.0. La fase lleva los hallazgos de ciberdefensa (Fases 4 y 5) al plano de las **operaciones**: define un control compensatorio para cada riesgo, integra un cortafuegos de aplicaciones web (WAF), una protección en tiempo de ejecución (RASP) con monitoreo de API y un sistema de gestión de eventos (SIEM), y verifica con pruebas repetibles qué protege cada capa y qué no.

La segunda parte formaliza el tratamiento del riesgo con el proceso de ISO/IEC 27005: 24 riesgos categorizados por tipo e impacto, una decisión de tratamiento por riesgo y matrices de calor antes y después de los controles. La escala, la derivación desde el análisis DREAD de la Fase 1 y las pautas de reducción son una **convención propia del equipo**: la norma define el proceso y las opciones de tratamiento, no una fórmula. El riesgo residual se fija por riesgo, con su justificación, y un validador automático rechaza cualquier reducción que no esté respaldada por un control **probado**.

Todas las pruebas se realizaron sobre instancias propias, expuestas solo en 127.0.0.1 o en redes internas de Docker. Ningún componente reporta a servicios externos y cada resultado remite a evidencia con hash SHA-256 (Anexo A) y a la bitácora de comandos (Anexo B). Se distinguen cinco niveles de verificación: **probado** (una prueba demostró el efecto), **inspeccionado** (configuración comprobada, efecto no ejercitado), **diseñado** (corrección validada como diff, no desplegada), **propuesto** y **no efectivo**.

Repositorio: https://github.com/jmolinap1-universidad/juice-shop-lab

Objetivos

Objetivo general

Operar la aplicación endurecida con controles en capas —perímetro, ejecución y monitoreo— y tratar formalmente cada riesgo, demostrando con evidencia verificable qué parte del riesgo inherente reduce cada control y cuál permanece.

Objetivos específicos

- Definir controles compensatorios para cada riesgo identificado, con tipo, nivel de verificación y evidencia.
- Configurar un WAF frente al OWASP Top 10:2025, distinguiendo reglas instaladas, observadas y probadas.
- Integrar un RASP y un monitoreo de API que detecten comportamientos anómalos sin degradar la disponibilidad.
- Centralizar los registros de auditoría en un SIEM con reglas de correlación y alerta, y asegurar el propio SIEM.
- Construir la matriz de decisiones, la categorización por tipo e impacto y las matrices de calor inherente y residual.

1. Estrategia de Mitigación y Ciberseguridad

La estrategia aplica defensa en profundidad. El WAF filtra en el perímetro; el RASP vigila dentro de la aplicación las operaciones peligrosas; el endurecimiento del contenedor de la Fase 5 contiene el daño; y el SIEM observa todas las capas. Ninguna capa se considera suficiente por sí misma, y los controles compensatorios no sustituyen a la corrección de la causa en el código.

1.1 Arquitectura operativa y defensa en profundidad

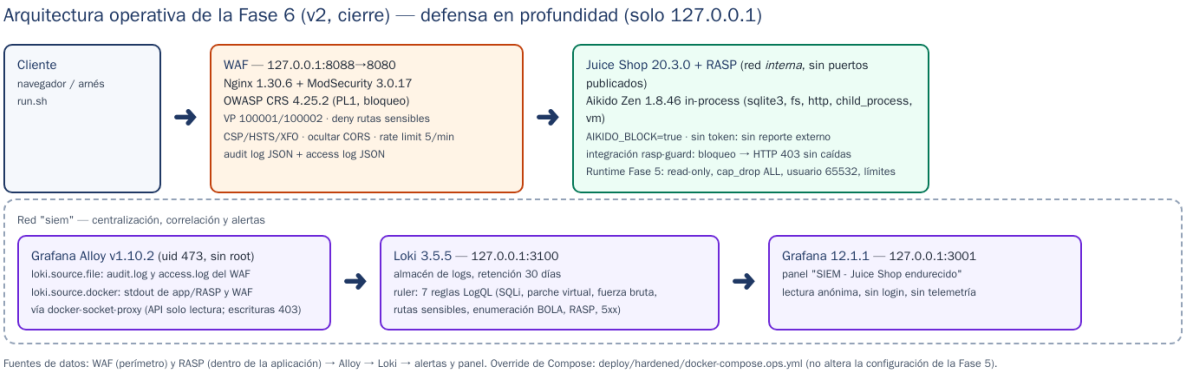


Figura 1. *Arquitectura operativa de la Fase 6 (versión de cierre): WAF en el perímetro, aplicación con RASP e integración rasp-guard en una red interna, y SIEM que consulta Docker a través de un proxy de solo lectura; todo expuesto solo en 127.0.0.1.*

El entorno se levanta con `make ops-up`, un archivo de Compose adicional que no altera la configuración auditada en la Fase 5. En la validación el WAF se publicó en `127.0.0.1:8088` porque el puerto 8080 estaba ocupado por un proceso Java del equipo, que no se interrumpió. La configuración resuelta de Compose publica solo `127.0.0.1:8088`, `127.0.0.1:3001` (Grafana) y `127.0.0.1:3100` (Loki). La telemetría externa está desactivada por configuración en los cuatro componentes; el tráfico de red saliente no se auditó con captura de red.

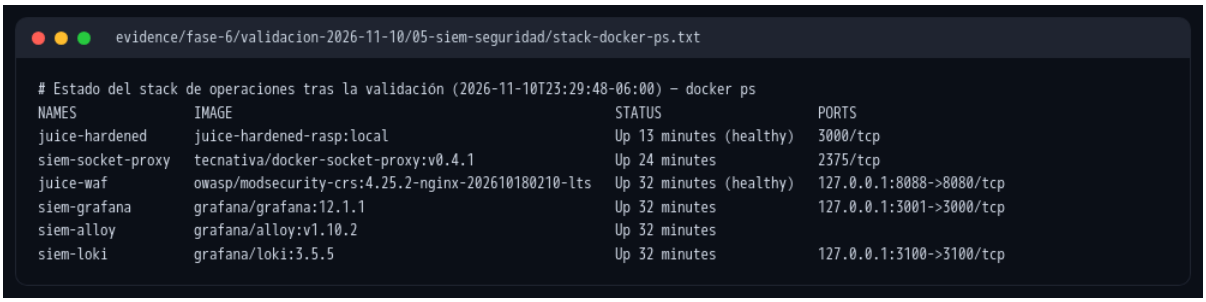


Figura 2. *Estado de los seis contenedores del entorno de operaciones tras la validación: WAF y aplicación healthy; solo Loki, Grafana y el WAF publican puertos, y únicamente en 127.0.0.1.*

1.2 Controles compensatorios por riesgo

Cada uno de los 24 riesgos tiene al menos un control, clasificado por tipo (preventivo, detectivo, de contención, de eliminación, de evitación o de transferencia) y por nivel de verificación. La Tabla 1 muestra el control principal de cada riesgo: el primero probado que no es solo detectivo o, si no existe, el control planificado. El detalle con todas las evidencias está en el Anexo D.

Tabla 1

Control compensatorio principal por riesgo y su nivel de verificación

ID	Riesgo	Control principal	Tipo	Verificación
R01	Inyección SQL en el login (bypass de autenticación)	WAF ModSecurity + CRS 942100/949110 (HTTP 403)	preventivo	Probado
R02	Inyección SQL UNION en búsqueda (extracción de tablas)	WAF ModSecurity + CRS 942xxx (HTTP 403)	preventivo	Probado
R03	Clave privada JWT embebida en el código (forja de tokens)	Parche 04: clave privada fuera del código (variable/secreto)	eliminacion	Sin verificar
R04	Bibliotecas JWT obsoletas (algoritmos débiles)	SCA en CI (npm audit, OSV, Grype) que identifica el componente	detectivo	Probado
R05	Contraseñas con MD5 sin sal	Bloqueo de la vía de extracción por SQLi (WAF + RASP)	preventivo	Probado
R06	BOLA/IDOR: lectura de recursos de otro usuario	Heurística SIEM API_Enumeracion_Objetos_PosibleBOLA (con falsos positivos demostrados)	detectivo	Probado
R07	Asignación masiva de role=admin en el registro	Parche virtual ModSecurity 100001 (HTTP 403)	preventivo	Probado
R08	Inyección NoSQL en reseñas (MarsDB)	Rechazar operadores en filtros de MarsDB	eliminacion	Sin verificar
R09	Ejecución de código vía eval()/vm	Contención: FS raíz de solo lectura (escritura bloqueada con EROFS), usuario no root, cap_drop ALL	contencion	Probado
R10	XXE en la carga de XML	Parser XML sin entidades externas ni DTD	eliminacion	Sin verificar
R11	SSRF en la imagen de perfil por URL	Lista blanca de destinos y filtrado de egreso	preventivo	Sin verificar
R12	Listado de directorios y archivos internos (/ftp, /support/logs, /encryptionkeys)	nginx deny de rutas sensibles (HTTP 403)	preventivo	Probado
R13	XSS (CSP débil, sin codificación de salida)	CSP (script-src 'self') y cabeceras en el WAF: presentes en la respuesta	preventivo	Inspeccionado
R14	CORS permisivo (ACAO *)	WAF oculta Access-Control-Allow-Origin (comprobado con Origin externo)	preventivo	Probado
R15	Redirección abierta (lista blanca evadible)	Comparación exacta de destinos permitidos	eliminacion	Sin verificar
R16	Fuerza bruta en el login (sin limitación de intentos)	Rate limiting nginx 5/min por IP, ráfaga 3 (HTTP 429)	preventivo	Probado
R17	/metrics expuesto sin autenticación	nginx deny /metrics + parche virtual 100002 (mismo componente WAF)	preventivo	Probado
R18	Denegación de servicio por vm/ZIP (agotamiento de recursos)	Límites de pids (200), memoria (1 GiB) y CPU (1.0) configurados	contencion	Inspeccionado
R19	Registro sin centralización ni alertas	SIEM: Alloy -> Loki -> Grafana; 3 fuentes ingestadas y 7 reglas (6 disparadas en las pruebas)	preventivo	Probado
R20	Dependencias con CVE críticas (cadena de suministro)	SCA en CI (npm audit, OSV, Grype, Trivy) en cada push	detectivo	Probado
R21	Configuración insegura al desplegar la arquitectura cloud (AWS)	No desplegar sin aprobación (sin terraform apply, sin .tfstate, sin credenciales AWS)	evitacion	Probado

ID	Riesgo	Control principal	Tipo	Verificación
R22	Bloqueo del RASP que deja peticiones colgadas o termina el proceso (auto-DoS)	Integración rasp-guard: el bloqueo en sqlite3 se entrega como error controlado HTTP 403 (sin --unhandled-rejections=warn)	eliminacion	Probado
R23	Exposición de datos personales (incumplimiento de protección de datos)	Bloqueo de la extracción masiva por SQLi (WAF + RASP)	preventivo	Probado
R24	SIEM del laboratorio: privilegio sobre Docker, un solo nodo, Loki sin autenticación	Proxy del socket de Docker de solo lectura (escrituras HTTP 403); Alloy sin root, sin socket, sin capacidades	contencion	Probado

Nota. Elaboración propia con datos del repositorio del laboratorio.

Los riesgos sin un control probado (entre ellos R03, R06, R08, R10, R11 y R15) no tienen hoy una protección compensatoria efectiva; su tratamiento depende de correcciones diseñadas o propuestas.

1.3 WAF: reglas para el OWASP Top 10:2025

El WAF combina Nginx 1.30.6, ModSecurity 3.0.17 y el OWASP Core Rule Set 4.25.2 en nivel de paranoia 1, en modo de bloqueo con puntuación de anomalía (umbral entrante 5, saliente 4). Sobre el CRS se añadieron dos parches virtuales (100001, rol en el registro; 100002, `/metrics`), denegación de rutas internas, cabeceras de seguridad, ocultación del CORS permisivo y limitación de tasa del inicio de sesión. Un WAF **no** cubre los diez riesgos: cadena de suministro, diseño inseguro e integridad de software requieren medidas fuera del perímetro.



evidence/fase-6/waf/crs-inventario.txt

```
# Inventario de reglas del WAF desplegado (Fase 6) — 2026-11-10T21:32:48-06:00
# Imagen: owasp/modsecurity-crs:4.25.2-nginx-202610180210-lts (contenedor juice-waf en ejecución)
# Formato: archivo|reglas con id
REQUEST-901-INITIALIZATION.conf|36
REQUEST-905-COMMON-EXCEPTIONS.conf|2
REQUEST-911-METHOD-ENFORCEMENT.conf|9
REQUEST-913-SCANNER-DETECTION.conf|9
REQUEST-920-PROTOCOL-ENFORCEMENT.conf|68
REQUEST-921-PROTOCOL-ATTACK.conf|26
REQUEST-922-MULTIPART-ATTACK.conf|7
REQUEST-930-APPLICATION-ATTACK-LFI.conf|14
REQUEST-931-APPLICATION-ATTACK-RFI.conf|13
REQUEST-932-APPLICATION-ATTACK-RCE.conf|55
REQUEST-933-APPLICATION-ATTACK-PHP.conf|29
REQUEST-934-APPLICATION-ATTACK-GENERIC.conf|19
REQUEST-941-APPLICATION-ATTACK-XSS.conf|42
REQUEST-942-APPLICATION-ATTACK-SQLI.conf|68
REQUEST-943-APPLICATION-ATTACK-SESSION-FIXATION.conf|11
REQUEST-944-APPLICATION-ATTACK-JAVA.conf|22
REQUEST-949-BLOCKING-EVALUATION.conf|28
REQUEST-999-COMMON-EXCEPTIONS-AFTER.conf|0
REQUEST-999-VIRTUAL-PATCHES.conf|2
RESPONSE-950-DATA-LEAKAGES.conf|15
RESPONSE-951-DATA-LEAKAGES-SQL.conf|26
RESPONSE-952-DATA-LEAKAGES-JAVA.conf|10
RESPONSE-953-DATA-LEAKAGES-PHP.conf|13
RESPONSE-954-DATA-LEAKAGES-IIS.conf|14
RESPONSE-955-WEB-SHELLS.conf|36
RESPONSE-956-DATA-LEAKAGES-RUBY.conf|11
RESPONSE-959-BLOCKING-EVALUATION.conf|28
RESPONSE-980-CORRELATION.conf|21

# Configuración efectiva relevante (variables del contenedor)
ANOMALY_INBOUND=5
ANOMALY_OUTBOUND=4
BLOCKING_PARANOIA=1
MODSEC_AUDIT_ENGINE=RelevantOnly
MODSEC_AUDIT_LOG_FORMAT=JSON
MODSEC_RULE_ENGINE=On
PARANOIA=1

# Versiones
nginx version: nginx/1.30.6
CRS: OWASP_CRS/4.25.2 (campo components del audit log; la cadena 3.1.0 del archivo de inicializacion es una referencia heredada, no la version)
ModSecurity: v3.0.17 (campo producer del audit log)

# Parches virtuales propios cargados
id:100001
id:100002
```

Figura 3. *Inventario de reglas del WAF desplegado: reglas por familia del CRS, configuración efectiva y parches virtuales cargados.*

Tabla 2

Cobertura del OWASP Top 10:2025: regla instalada, observada en logs, vector probado y corrección pendiente

OWASP 2025	Control WAF	Instalada	Observada	Probado y bloqueado	Raíz pendiente
A01 Broken Access Control	Deny de rutas; VP 100001; CRS 930/931	Sí	100001	Rutas y rol: 403. BOLA: NO	Parches 06 y 08
A02 Security Misconfiguration	Cabeceras; CORS; deny /metrics + VP 100002; CRS 920/921/913	Sí	920350, 100002	Cabeceras, ACAO oculto, /metrics 403	Parche 07; config. de la app
A03 Supply Chain Failures	—	—	—	No aplica al WAF	Actualizar dependencias
A04 Cryptographic Failures	HSTS; CRS 950-956	Sí	No	Solo HSTS presente	Parches 03 y 04

OWASP 2025	Control WAF	Instalada	Observada	Probado y bloqueado	Raíz pendiente
A05 Injection	CRS 942, 941, 932, 934, 943	Sí	942xxx, 949110	Solo SQLi; XSS/RCE/LFI configurado, no probado	Parches 01, 02 y 05
A06 Insecure Design	—	—	—	No aplica al WAF	Modelado y parches
A07 Authentication Failures	limit_req 5/min, ráfaga 3	Sí	8 × 429	Fuerza bruta desde una IP	Limitación por cuenta
A08 Integrity Failures	—	—	—	No aplica al WAF	—
A09 Logging & Alerting Failures	Audit y access log JSON al SIEM	Sí	Sí	Ver 1.6	Notificaciones, HA
A10 Exceptional Conditions	CRS 920 (peticiones malformadas)	Sí	920350	No probado	Errores sin traza de pila

Nota. Elaboración propia con datos del repositorio del laboratorio.

Reglas observadas en los audit logs de la validación: 920350 (×43, solo advertencia), 942100 (×3), 942190 (×2), 942270 (×2), 942140 (×1), 949110 (×3), 100001 y 100002. El endpoint `/encryptionkeys/jwt.pub` sirve una **clave pública**: no es una vulnerabilidad y su bloqueo es reducción de superficie; el hallazgo real es la clave **privada** embebida en el código (R03). La regla 920350 («Host header is a numeric IP address») apareció en 43 de 43 peticiones auditadas porque el laboratorio se accede por IP, y además vuelve «relevante» cada petición para el audit log. Excluirla en el laboratorio queda como **recomendación**: no se aplicó para no alterar la configuración medida.

1.4 RASP: detección y bloqueo en tiempo de ejecución

El RASP es **Aikido Zen 1.8.46** (código abierto, AGPL-3.0), cargado dentro del proceso Node.js con `NODE_OPTIONS` sobre la imagen oficial fijada por digest. Instrumenta `sqlite3`, el sistema de archivos, la ejecución de procesos, las peticiones HTTP salientes y `node:vm`, y sin token no reporta a terceros. Puede solo detectar (`AIKIDO_BLOCK=false`) o bloquear (`AIKIDO_BLOCK=true`).

La primera iteración reveló que el modo bloqueo degradaba la disponibilidad. La causa está en el código de Sequelize: cada consulta corre dentro de `conn.serialize(async () => …)` (`query.js:183`). Zen bloquea **lanzando** un error síncrono desde `sqlite3.Database#all`; esa excepción rechaza la promesa de la función `async`, que `serialize` ignora. La consulta nunca se resuelve, la ruta no recibe el error y, según la configuración de Node, el proceso termina o la petición queda colgada.

La solución es la integración `deploy/hardened/rasp/rasp-guard.js`, cargada después del agente y sin modificar Juice Shop ni Sequelize. Solo intercepta los errores cuyo mensaje empieza por `Zen has blocked`: los entrega por el callback de `sqlite3`, que es la vía de error que Sequelize sí propaga, y fija HTTP 403 en la respuesta de esa petición. Cualquier otro error se relanza, y se retiró `--unhandled-rejections=warn`, que habría ocultado otros fallos. La Tabla 3 y la Figura 4 comparan las configuraciones medidas sin WAF delante, con el código HTTP real de cada petición, una sonda de disponibilidad y el contador de reinicios.

Tabla 3

Configuraciones del RASP medidas sin WAF (A1-A3 = inyecciones SQL del arnés)

Escenario	Configuración	A1-A3	Disponibilidad	Reinicios	Lectura
2a	Monitoreo	200 (detectadas)	41/41	0 → 0	Detecta sin bloquear
2b	Bloqueo por defecto	000	1/6	0 → 1	Caída del proceso (auto-DoS)
2c	Bloqueo + warn	000 a los 20,0 s	106/106	0 → 0	Petición colgada: no es bloqueo válido
2d	Bloqueo + rasp-guard	403 en 0,04-0,15 s	41/41	0 → 0	Bloqueo controlado
3b	Bloqueo + rasp-guard + SIEM	403	41/41	0 → 0	Eventos en Loki; alerta en firing

Nota. Elaboración propia con datos del repositorio del laboratorio.

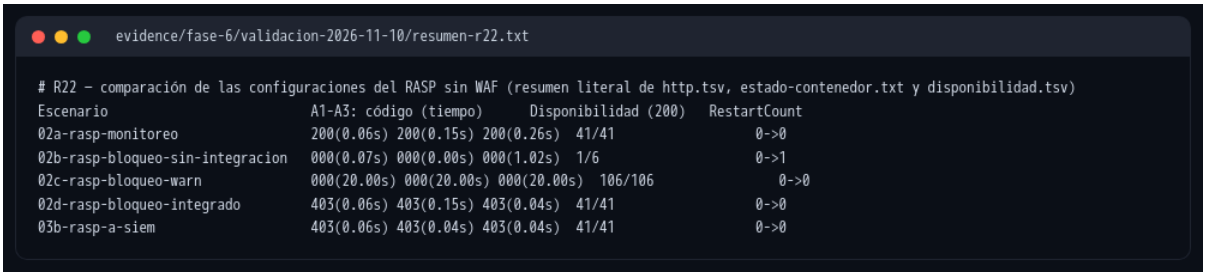


Figura 4. *Resumen literal de la evidencia de los escenarios del RASP: código HTTP y tiempo de A1-A3, disponibilidad medida por la sonda y contador de reinicios.*



Figura 5. *Escenario 2b: el primer bloqueo termina el proceso Node (rechazo no manejado), las peticiones obtienen 000 y la sonda falla 5 de 6 veces. Los «MITIGADO» que cuenta el arnés en esta corrida no son mitigaciones.*

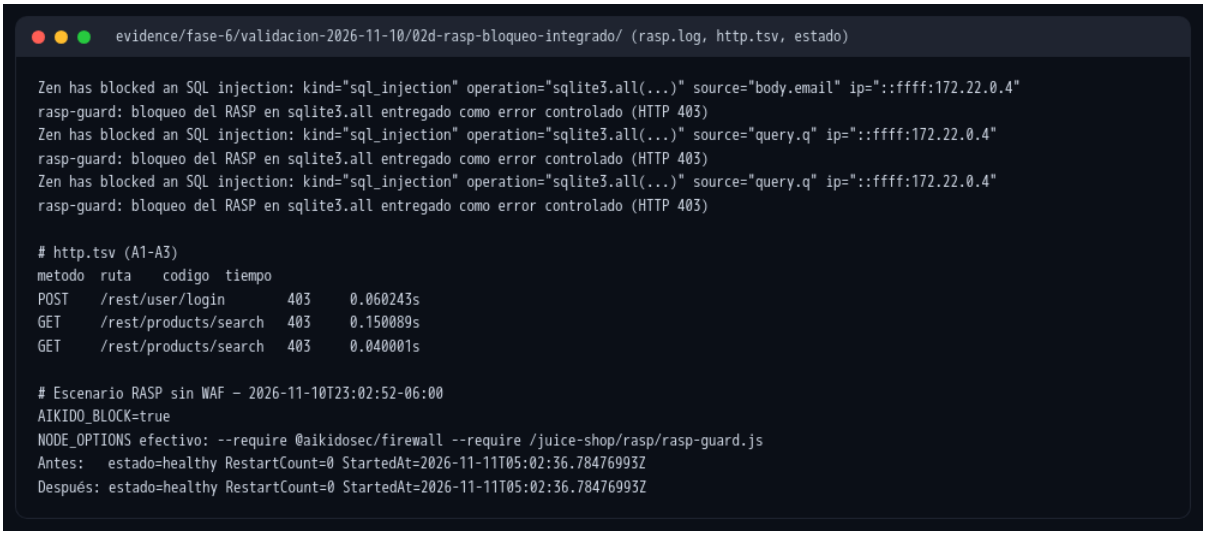


Figura 6. *Escenario 2d: cada bloqueo deja «Zen has blocked» y «rasp-guard … (HTTP 403)»; A1-A3 reciben 403 y el contenedor no se reinicia.*

El alcance del RASP tiene límites que conviene declarar. Solo se probó el sink `sqlite3`: los bloqueos en `fs`, `http`, `child_process` y `vm` no se ejercitaron, por lo que R22 queda **ejecutado parcialmente**. El cuerpo del 403 lo genera el manejador de errores de Juice Shop, que muestra una traza de pila (comportamiento preexistente, A10). Además, el RASP no cubre exposiciones de configuración, asignación masiva, rate limit, BOLA ni NoSQL sobre MarsDB: sin WAF, A4-A12 siguen presentes.

1.5 Monitoreo de APIs: heurística de comportamiento anómalo

El monitoreo de API se implementa como reglas de correlación sobre el registro de acceso del WAF, que no almacena cabeceras de autorización ni cuerpos. La regla `API_Enumeracion_Objetos_PosibleBOLA` (dos o más cestas distintas con HTTP 200 en cinco minutos) es una **heurística**: no comprueba la propiedad del objeto ni prueba que haya ocurrido un BOLA. La prueba del BOLA es el caso A12 con dos tokens.

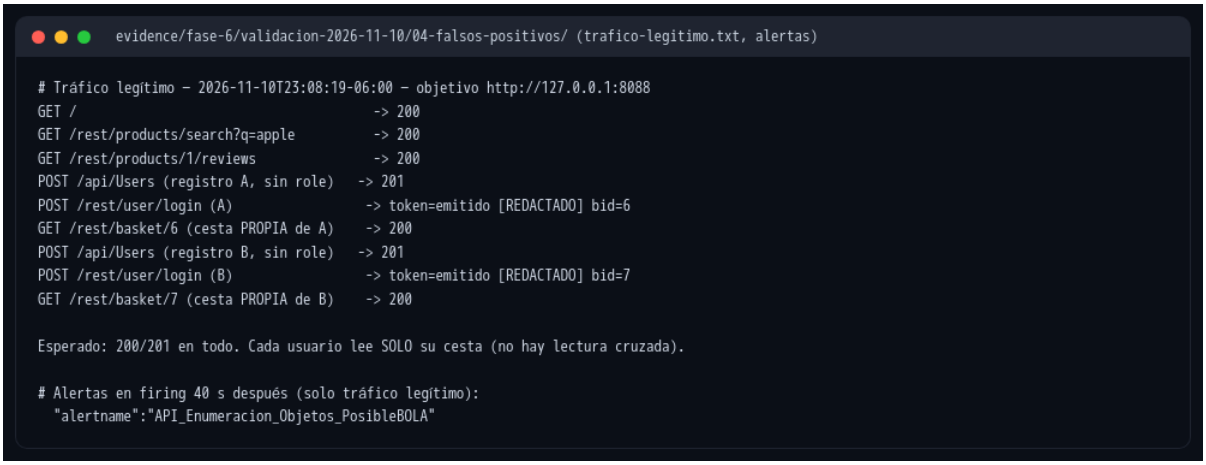


Figura 7. *Escenario 4: dos usuarios legítimos leen cada uno su propia cesta; todas las operaciones son correctas y, aun así, la heurística BOLA entra en firing: falso positivo demostrado.*

El falso positivo se explica porque la correlación es global: todo el tráfico llega con la IP de la pasarela de Docker y la regla no conoce la identidad del usuario. Hay también un **falso negativo** (por análisis, no probado): un atacante que lea una sola cesta ajena en cinco minutos no alcanza el umbral. Como mejora se propone, sin implementarla, registrar un identificador seudónimo del usuario (por ejemplo, un HMAC del `sub` del JWT, nunca el token) para correlacionar objetos distintos por usuario; seguiría siendo una heurística. La regla de fuerza bruta se activó; la de errores 5xx está configurada, pero no se disparó en ningún escenario.

1.6 SIEM: centralización y correlación de logs

El SIEM usa Grafana Alloy v1.10.2 para recolectar, Loki 3.5.5 para almacenar (30 días) y evaluar las reglas cada 15 segundos, y Grafana 12.1.1 para el panel. Las fuentes son el audit log de ModSecurity, el access log JSON del WAF y la salida estándar de la aplicación (incluido el RASP) y del WAF.

Tabla 4

Reglas de correlación del SIEM y su estado en los escenarios 3 (vía WAF) y 3b (RASP sin WAF)

Regla	Escenario 3	Escenario 3b	Comentario
WAF_InyeccionSQL_Bloqueada	firing	firing	3 eventos CRS 942
WAF_ParcheVirtual_Activado	firing	firing	100001 y 100002
Login_FuerzaBruta_RateLimit	firing	firing	8 respuestas 429
Acceso_Rutas_Sensibles_Denegado	firing	firing	403 en rutas internas
API_Enumeracion_Objetos_PosibleBOLA	firing	firing	Heurística con falsos positivos
RASP_Ataque_Detectado	inactive	firing	En 3 el WAF frenó la SQLi antes de la app
App_Errores_5xx	inactive	inactive	Configurada, no disparada

Nota. Elaboración propia con datos del repositorio del laboratorio.

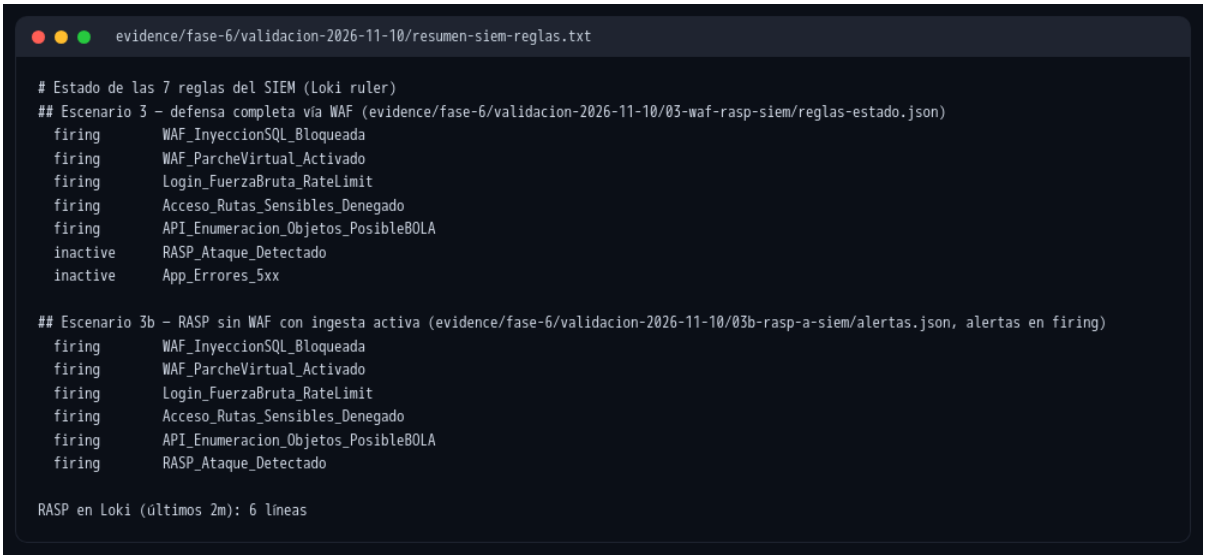


Figura 8. *Estado de las siete reglas: cinco en firing vía WAF (la del RASP queda inactiva porque el WAF frenó la inyección) y la regla del RASP en firing cuando la app se ataca sin WAF.*

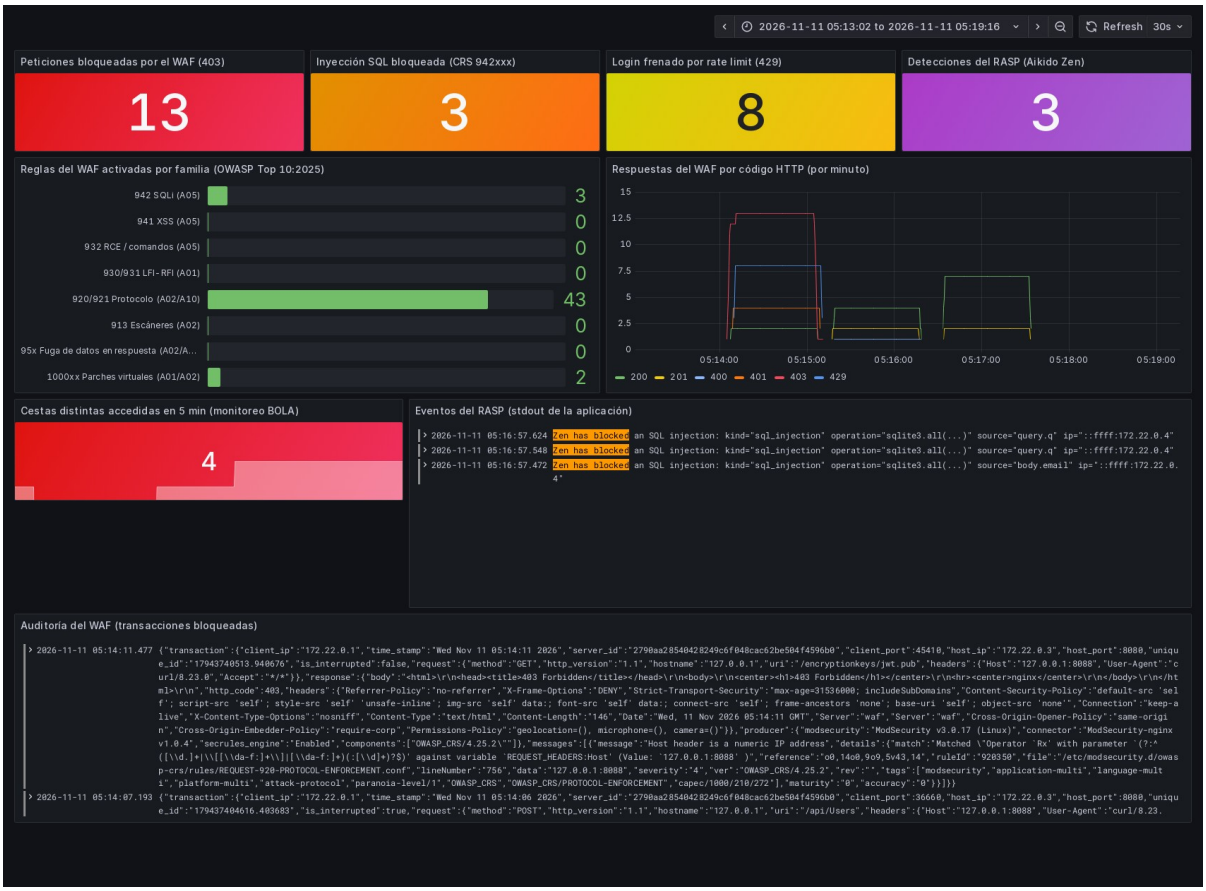


Figura 9. *Panel del SIEM en Grafana para la ventana de los escenarios 3 y 3b: bloqueos del WAF, SQLi, rate limit, eventos del RASP, reglas por familia, respuestas por código y monitoreo BOLA.*



Figura 10. *Métricas LogQL de la ventana del escenario 3: 13 respuestas 403, 8 respuestas 429, 3 eventos CRS 942, 920350 en 34 de 34 transacciones auditadas y 0 eventos del RASP.*

La seguridad del propio SIEM también se trató (riesgo R24). En la primera iteración Alloy corría como root con `docker.sock` montado `:ro`, pero el montaje de solo lectura **no restringe la API de Docker**: quien controlara Alloy podía crear o ejecutar contenedores. Ahora Alloy corre como uid 473, sin capacidades y sin el socket, y consulta Docker a través de un proxy que solo permite lecturas (Figura 11). Al introducir el proxy,

el SIEM dejó de ingerir los logs de contenedores durante unos 11 minutos, porque Alloy necesita `GET /networks`; se corrigió habilitando solo esa lectura. La incidencia muestra que hace falta una alerta por ausencia de datos de cada fuente. Loki sin autenticación, Grafana anónimo en loopback y el nodo único se aceptan temporalmente para el laboratorio: no son una configuración apta para producción.



Figura 11. *Proxy del socket de Docker probado desde la red interna: lecturas 200; crear, detener, ejecutar, borrar contenedores y descargar imágenes 403. Alloy sin root, sin capacidades y sin socket.*

1.7 Validación integral de los controles

La Tabla 5 resume los escenarios ejecutados con el mismo arnés (código HTTP real de cada petición; 000 significa sin respuesta y nunca se cuenta como bloqueo). Antes de medir la protección se comprobó que el tráfico legítimo funcionara: en el escenario 4, las nueve operaciones de dos usuarios fueron correctas (siete con código 200/201 y dos inicios de sesión con token emitido), sin falsos positivos del WAF ni del RASP.

Tabla 5

Escenarios de validación y qué capa protege en cada uno

#	Escenario	Resultado	Capa que actúa
1	Línea base vulnerable	11/11 condiciones + BOLA; A1-A3 con 200	Ninguna
2a-2d	RASP sin WAF	Ver Tabla 3	RASP (solo inyección)
3	WAF + RASP + SIEM	A1-A11 neutralizadas; A12 BOLA vulnerable (200)	WAF (perímetro); SIEM (detección)
3b	RASP sin WAF con SIEM	A1-A3 con 403; alerta del RASP en firing	RASP + SIEM
4	Tráfico legítimo	9 operaciones correctas; heurística BOLA con falso positivo	Ninguna bloquea; SIEM alerta de más

Nota. Elaboración propia con datos del repositorio del laboratorio.

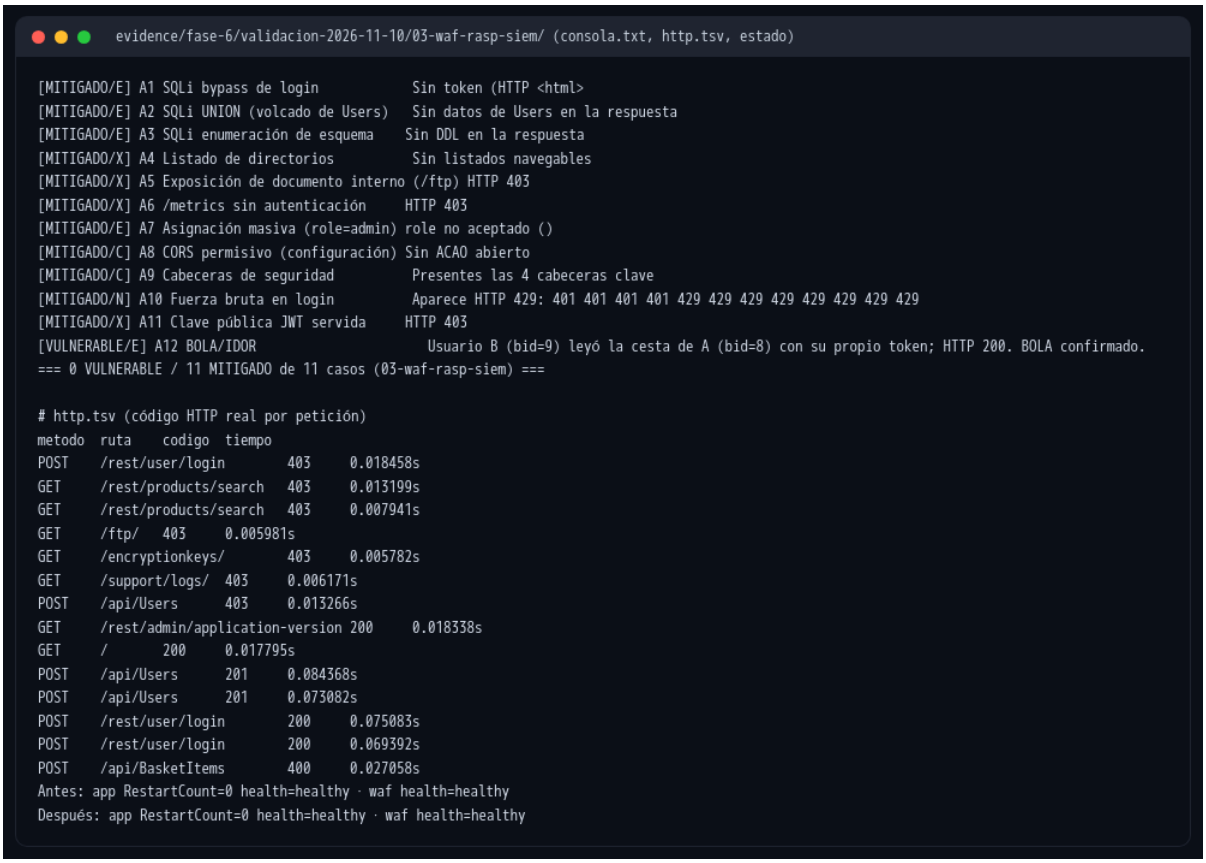


Figura 12. *Escenario 3 a través del WAF: las once condiciones A1-A11 quedan neutralizadas (403 del WAF en 0,008-0,018 s para la SQLi; 429 en fuerza bruta); el caso A12 (BOLA) sigue vulnerable con HTTP 200.*

Los once casos A1-A11 son **condiciones del arnés**, no once explotaciones: cuatro son explotación demostrada y siete son exposiciones, configuraciones inseguras o ausencia de controles. A través del WAF quedan neutralizadas, pero la causa sigue en el código. El BOLA continúa explotable porque un WAF evalúa peticiones, no la propiedad de los objetos; su eliminación requiere desplegar el parche 08, que verifica el propietario y responde 403 y que está validado solo como diff.

2. Tratamiento Formal del Riesgo

El tratamiento sigue el ciclo de ISO/IEC 27005:2022 (identificar, analizar, evaluar, tratar). El registro contiene 24 riesgos: las 20 amenazas STRIDE de la Fase 1 y cuatro riesgos adicionales (despliegue en la nube, cumplimiento de protección de datos, el comportamiento del bloqueo del RASP y la seguridad del propio SIEM). Los datos están en `docs/fase-6/datos/riesgos.json`; `make risk` valida, calcula y regenera tablas y figuras.

2.1 Método de valoración

- **Escala:** probabilidad (P) e impacto (I) de 1 a 5; nivel = P × I: Bajo 1-4, Medio 5-9, Alto 10-16, Crítico 20-25. Es una convención del equipo; ISO/IEC 27005 no prescribe esta aritmética.
- **Inherente:** P = media(Reproducibilidad, Explotabilidad, Descubribilidad) / 2 e I = media(Daño, Afectados) / 2, ambas redondeadas hacia arriba, desde el DREAD de la Fase 1. R21-R24 usan una valoración cualitativa justificada; R22 se apoya en la medición del escenario 2b.
- **Residual:** valor explícito por riesgo, con el razonamiento de P y de I. P solo baja con controles preventivos, de eliminación o de evitación **probados**; I solo baja con contención o respuesta **probadas**. La detección aporta visibilidad y no reduce el impacto. Los controles inspeccionados, diseñados o propuestos no reducen el residual.
- **Validación automática:** 301 comprobaciones (24 identificadores, escala, reducciones respaldadas, coherencia entre decisión y estado, aceptaciones con condiciones, transferencias propuestas marcadas como tales, rutas de evidencia existentes y recuentos que suman 24). Una prueba negativa confirma que el validador rechaza reducciones sin control probado.

2.2 Opciones de tratamiento

Tabla 6

Opciones de tratamiento y su uso en el proyecto

Decisión	Significado
Mitigar	Reducir probabilidad o impacto con controles (ISO/IEC 27005: modificar). No elimina la causa.
Eliminar	Suprimir la causa raíz (corregir el código o la configuración). Registrarla como plan no equivale a haberla eliminado.
Evitar	No realizar la actividad o retirar la funcionalidad que origina el riesgo.
Transferir	Compartir el riesgo con un tercero (proveedor gestionado, póliza o contrato). No transfiere la responsabilidad del titular; en este proyecto solo está propuesta.
Aceptar	Retener el riesgo de forma consciente, documentada, temporal y con condiciones (ISO/IEC 27005: retener).

Nota. Elaboración propia con datos del repositorio del laboratorio.

2.3 Categorización del riesgo por tipo e impacto

Distribución por tipo: Seguridad 16; Software 2; Técnico 2; Operacional 2; Cloud 1; Cumplimiento 1. Impactos (riesgos que los incluyen): Reputacional 19; Legal 13; Financiero 10; Operacional 10.

Tabla 7

Registro de riesgos: tipo, impactos (principal primero), OWASP y CWE

ID	Riesgo	Tipo	Impactos	OWASP 2025	CWE
R01	Inyección SQL en el login (bypass de autenticación)	Seguridad	Reputacional, Legal, Financiero	A05:2025	CWE-89
R02	Inyección SQL UNION en búsqueda (extracción de tablas)	Seguridad	Legal, Reputacional, Financiero	A05:2025	CWE-89
R03	Clave privada JWT embebida en el código (forja de tokens)	Seguridad	Reputacional, Legal, Financiero	A04:2025	CWE-798/321
R04	Bibliotecas JWT obsoletas (algoritmos débiles)	Software	Reputacional, Financiero	A03:2025	CWE-347
R05	Contraseñas con MD5 sin sal	Seguridad	Legal, Reputacional	A04:2025	CWE-916
R06	BOLA/IDOR: lectura de recursos de otro usuario	Seguridad	Legal, Reputacional	A01:2025 (API1:2023)	CWE-639
R07	Asignación masiva de role=admin en el registro	Seguridad	Reputacional, Financiero	A01:2025	CWE-915
R08	Inyección NoSQL en reseñas (MarsDB)	Seguridad	Reputacional, Operacional	A05:2025	CWE-943
R09	Ejecución de código vía eval()/vm	Seguridad	Operacional, Reputacional, Financiero	A05:2025	CWE-95
R10	XXE en la carga de XML	Seguridad	Legal, Operacional	A02:2025	CWE-611
R11	SSRF en la imagen de perfil por URL	Seguridad	Operacional, Legal	A01:2025	CWE-918
R12	Listado de directorios y archivos internos (/ftp, /support/logs, /encryptionkeys)	Seguridad	Reputacional, Legal	A02:2025	CWE-548/538
R13	XSS (CSP débil, sin codificación de salida)	Seguridad	Reputacional, Legal	A05:2025	CWE-79
R14	CORS permisivo (ACAO *)	Seguridad	Reputacional	A02:2025	CWE-942
R15	Redirección abierta (lista blanca evadible)	Seguridad	Reputacional	A01:2025	CWE-601
R16	Fuerza bruta en el login (sin limitación de intentos)	Seguridad	Reputacional, Operacional	A07:2025	CWE-307
R17	/metrics expuesto sin autenticación	Seguridad	Reputacional	A02:2025	CWE-200

ID	Riesgo	Tipo	Impactos	OWASP 2025	CWE
R18	Denegación de servicio por vm/ZIP (agotamiento de recursos)	Técnico	Operacional, Financiero	A10:2025	CWE-400
R19	Registro sin centralización ni alertas	Operacional	Operacional, Legal	A09:2025	CWE-778
R20	Dependencias con CVE críticas (cadena de suministro)	Software	Financiero, Reputacional, Legal	A03:2025	CWE-1395
R21	Configuración insegura al desplegar la arquitectura cloud (AWS)	Cloud	Financiero, Operacional, Legal	A02:2025	CWE-16
R22	Bloqueo del RASP que deja peticiones colgadas o termina el proceso (auto-DoS)	Técnico	Operacional, Reputacional	A10:2025	CWE-248/755
R23	Exposición de datos personales (incumplimiento de protección de datos)	Cumplimiento	Legal, Reputacional, Financiero	A01/A05:2025	CWE-200
R24	SIEM del laboratorio: privilegio sobre Docker, un solo nodo, Loki sin autenticación	Operacional	Operacional, Reputacional	A09:2025	CWE-250

Nota. Elaboración propia con datos del repositorio del laboratorio.

2.4 Matriz de decisiones y plan de tratamiento

Cada riesgo tiene una decisión principal y, si aplica, una complementaria, cada una con su estado real: Ejecutado, Ejecutado parcialmente, Planificado, Aceptado temporalmente o Propuesta. Decisiones principales: Mitigar 13, Eliminar 8, Aceptar 2, Evitar 1, Transferir 0. Transferir aparece solo como complementaria propuesta (R03, R21, R23): no existe contrato ni póliza, y transferir no exime al titular de su responsabilidad. Una decisión «Eliminar» en estado Planificado no significa que el riesgo esté eliminado.

Tabla 8

Matriz de decisiones: inherente, decisión (estado), complementaria (estado), residual y prioridad

ID	Inherente	Decisión (estado)	Complementaria (estado)	Residual	Prioridad
R01	5×5=25 Crítico	Mitigar (Ejecutado)	Eliminar (Planificado)	2×5=10 Alto	Alta
R02	5×5=25 Crítico	Mitigar (Ejecutado)	Eliminar (Planificado)	2×5=10 Alto	Alta
R03	4×5=20 Crítico	Eliminar (Planificado)	Transferir (Propuesta)	4×5=20 Crítico	Muy alta
R04	3×5=15 Alto	Aceptar (Aceptado temporalmente)	Eliminar (Planificado)	3×5=15 Alto	Alta
R05	4×5=20 Crítico	Eliminar (Planificado)	Mitigar (Ejecutado parcialmente)	3×5=15 Alto	Alta
R06	5×4=20 Crítico	Eliminar (Planificado)	Mitigar (Ejecutado parcialmente)	5×4=20 Crítico	Muy alta
R07	4×4=16 Alto	Mitigar (Ejecutado)	Eliminar (Planificado)	2×4=8 Medio	Media
R08	4×4=16 Alto	Eliminar (Planificado)	—	4×4=16 Alto	Alta
R09	3×5=15 Alto	Eliminar (Planificado)	Mitigar (Ejecutado)	3×4=12 Alto	Alta
R10	3×5=15 Alto	Eliminar (Planificado)	—	3×5=15 Alto	Alta
R11	4×3=12 Alto	Mitigar (Planificado)	Eliminar (Planificado)	4×3=12 Alto	Alta
R12	5×4=20 Crítico	Mitigar (Ejecutado)	Evitar (Planificado)	3×4=12 Alto	Alta
R13	4×4=16 Alto	Mitigar (Ejecutado parcialmente)	Eliminar (Planificado)	4×4=16 Alto	Alta
R14	4×3=12 Alto	Mitigar (Ejecutado)	Eliminar (Planificado)	2×3=6 Medio	Media
R15	4×3=12 Alto	Eliminar (Planificado)	—	4×3=12 Alto	Alta
R16	5×3=15 Alto	Mitigar (Ejecutado)	—	3×3=9 Medio	Media
R17	5×2=10 Alto	Mitigar (Ejecutado)	Evitar (Planificado)	3×2=6 Medio	Media

ID	Inherente	Decisión (estado)	Complementaria (estado)	Residual	Prioridad
R18	3×4=12 Alto	Mitigar (Ejecutado parcialmente)	—	3×4=12 Alto	Alta
R19	3×4=12 Alto	Mitigar (Ejecutado parcialmente)	Eliminar (Planificado)	2×4=8 Medio	Media
R20	4×5=20 Crítico	Aceptar (Aceptado temporalmente)	Eliminar (Planificado)	4×5=20 Crítico	Muy alta
R21	3×4=12 Alto	Evitar (Ejecutado)	Transferir (Propuesta)	1×4=4 Bajo	Baja
R22	5×3=15 Alto	Eliminar (Ejecutado parcialmente)	—	2×3=6 Medio	Media
R23	5×5=25 Crítico	Mitigar (Ejecutado parcialmente)	Transferir (Propuesta)	4×5=20 Crítico	Muy alta
R24	2×5=10 Alto	Mitigar (Ejecutado)	Aceptar (Aceptado temporalmente)	2×3=6 Medio	Media

Nota. Elaboración propia con datos del repositorio del laboratorio.

Tabla 9

Plan de tratamiento: responsable (por rol), criterio de revisión y actividad pendiente

ID	Responsable (rol)	Revisión	Pendiente
R01	Operaciones de seguridad (WAF/RASP); Desarrollo backend (parche 01)	Al desplegar el parche 01: repetir run.sh sin WAF y comprobar A1 sin vulnerabilidad	Recompilar la aplicación con el parche 01 (consulta parametrizada) y verificarlo
R02	Operaciones de seguridad (WAF/RASP); Desarrollo backend (parche 02)	Al desplegar el parche 02: repetir run.sh sin WAF (A2-A3)	Recompilar con el parche 02 y verificarlo
R03	Desarrollo backend (parche 04); Arquitectura cloud (gestor de secretos)	Antes de cualquier despliegue fuera del laboratorio; al aplicar el parche 04	Aplicar el parche 04 (manual: la clave no se versiona), rotar la clave y cargarla desde un gestor de secretos
R04	Dueño del riesgo: líder del proyecto (acepta); Desarrollo backend (actualización)	En cada ejecución del pipeline SCA y antes de cualquier uso fuera del laboratorio	Actualizar jsonwebtoken/express-jwt y fijar algorithms: ['RS256'] en un entorno que no dependa de los retos
R05	Desarrollo backend (parche 03)	Al desplegar el parche 03 (rehash progresivo al iniciar sesión)	Aplicar el parche 03 (bcrypt) con migración de hashes existentes
R06	Desarrollo backend (parche 08); Monitoreo (heurística SIEM)	Al desplegar el parche 08: repetir A12 (debe responder 403) y el tráfico legítimo	Aplicar, compilar y probar el parche 08; extender la verificación de propietario a Addresses, Cards y Feedbacks
R07	Operaciones de seguridad (parche virtual); Desarrollo backend (parche 06)	Al desplegar el parche 06; revisión del parche virtual si cambia el modelo de usuario	Aplicar el parche 06 (lista blanca de campos)
R08	Desarrollo backend	Al implementar la validación de operadores; incluir un caso en run.sh	Rechazar operadores ($ne, $where...) en filtros y añadir un caso de prueba
R09	Desarrollo backend (parche 05); Operaciones (runtime)	Al desplegar el parche 05	Aplicar el parche 05 (eliminar eval) y revisar b2bOrder/captcha (vm)
R10	Desarrollo backend	Al endurecer el parser; añadir caso de prueba	Configurar el parser XML sin entidades externas ni DTD
R11	Desarrollo backend; Operaciones (filtrado de egreso)	Al implementar la lista blanca; probar con un destino interno del laboratorio	Lista blanca de destinos y filtrado de egreso de red
R12	Operaciones de seguridad (WAF); Desarrollo backend (retirar serve-index)	Al retirar serve-index: repetir A4-A5 sin WAF	Retirar los listados y los archivos internos del servidor web (Evitar)
R13	Operaciones de seguridad (CSP); Desarrollo frontend (codificación de salida)	Al añadir casos de XSS al arnés (reflejado y persistente)	Probar vectores XSS concretos contra el laboratorio y aplicar codificación de salida
R14	Operaciones de seguridad (WAF); Desarrollo backend (parche 07)	Al desplegar el parche 07	Aplicar el parche 07 (origen explícito)
R15	Desarrollo backend	Al corregir la comparación de destinos	Comparación exacta de destinos permitidos
R16	Operaciones de seguridad (WAF)	Si se publica detrás de un balanceador (revisar la IP de cliente usada por limit_req)	Limitación por cuenta además de por IP (ataques distribuidos no probados)
R17	Operaciones de seguridad (WAF); Monitoreo (red de métricas)	Al exponer métricas a un recolector: solo por red interna y con autenticación	Servir /metrics solo en la red de monitoreo (Evitar la exposición en la app)
R18	Operaciones (runtime)	Tras una prueba de carga controlada en el laboratorio	Prueba de carga controlada que demuestre el efecto de los límites

ID	Responsable (rol)	Revisión	Pendiente
R19	Monitoreo (SIEM)	Al añadir notificaciones y monitorear la propia ingesta	Notificación externa (Alertmanager/correo), alta disponibilidad y alerta por ausencia de datos de cada fuente
R20	Dueño del riesgo: líder del proyecto (acepta); Desarrollo (actualización)	En cada push (SCA en CI) y antes de cualquier uso fuera del laboratorio	Actualizar crypto-js, lodash, marsdb y demás en un entorno que no dependa de los retos
R21	Arquitectura cloud; Dueño del riesgo: líder del proyecto (aprobación de costos)	Antes de cualquier terraform apply: pruebas en ejecución además de Checkov	Si se despliega: validar la seguridad en ejecución (no solo estática) y revaluar este riesgo
R22	Operaciones de seguridad (integración del RASP)	Al ejercitar bloqueos en los sinks fs, http, child_process y vm	Probar el bloqueo en los demás sinks y extender rasp-guard si es necesario; respuesta 403 sin traza de pila
R23	Dueño del riesgo: líder del proyecto; Desarrollo backend (R06)	Al cerrar R06 (BOLA) y antes de tratar datos reales	Eliminar el BOLA (parche 08) y evaluar póliza o cláusulas contractuales si hubiera datos reales
R24	Monitoreo (SIEM); Dueño del riesgo: líder del proyecto (acepta un solo nodo)	Antes de cualquier uso fuera del laboratorio	Autenticación en Loki y Grafana, alta disponibilidad, notificaciones y alerta por pérdida de ingesta

Nota. Elaboración propia con datos del repositorio del laboratorio.

Los responsables se expresan por rol; el equipo asigna la persona de cada rol. Las aceptaciones temporales (Tabla 10) se limitan al laboratorio: en producción no serían aceptaciones automáticas.

Tabla 10

Aceptaciones temporales: quién acepta, motivo, condiciones y vigencia

ID	Quién acepta	Motivo	Condiciones	Vigencia
R04	Líder del proyecto (rol de dueño del riesgo; el equipo asigna la persona)	Actualizar las bibliotecas rompe retos de OWASP Juice Shop, que es el objeto de estudio del laboratorio.	Solo en el laboratorio: escucha en 127.0.0.1, sin datos reales ni usuarios externos; la versión vulnerable nunca se publica.	Hasta el cierre del curso. No aplica a producción, donde la decisión es Eliminar.
R20	Líder del proyecto (rol de dueño del riesgo; el equipo asigna la persona)	La aplicación es intencionalmente vulnerable; actualizar dependencias rompe los retos que se estudian.	Solo en el laboratorio aislado (127.0.0.1), sin datos reales; WAF y RASP delante; SCA en cada push.	Hasta el cierre del curso. En producción: Eliminar (nunca aceptación automática).
R24	Líder del proyecto (rol de dueño del riesgo; el equipo asigna la persona)	Un SIEM de un solo nodo, sin autenticación en Loki, basta para demostrar la centralización y la correlación en el laboratorio.	Puertos solo en 127.0.0.1; proxy del socket de solo lectura; red del proxy interna; sin telemetría externa.	Solo en el laboratorio. No es una configuración apta para producción.

Nota. Elaboración propia con datos del repositorio del laboratorio.

2.5 Justificación del riesgo residual

Tabla 11

Razonamiento del residual por riesgo (P e I)

ID	Inh. → Res.	Razón de P	Razón de I
R01	5×5 → 2×5	Dos capas preventivas independientes probadas (WAF y RASP en el sink) bloquean el vector: P-3. No llega a 1 porque la causa (consulta concatenada) sigue en el código y una evasión del CRS en PL1 no está descartada.	Si el ataque prospera, la consecuencia es la misma (sesión de administrador). Las alertas no reducen el impacto.
R02	5×5 → 2×5	Dos capas preventivas independientes probadas: P-3. La causa sigue en el código.	La extracción de tablas tendría la misma consecuencia; la detección no la reduce.
R03	4×5 → 4×5	Ningún control desplegado impide ni detecta un JWT forjado con la clave embebida.	Forjar tokens de cualquier usuario sigue siendo posible.
R04	3×5 → 3×5	El SCA identifica el componente pero no lo actualiza: la vulnerabilidad sigue presente.	Sin cambio: la detección no reduce el impacto.
R05	4×5 → 3×5	Solo se bloqueó UNA vía de exposición de hashes (SQLi): P-1. Otras vías (XXE R10, respaldos u otros IDOR) no están probadas y el algoritmo sigue siendo MD5.	Si los hashes se filtran, MD5 sin sal sigue siendo trivial de revertir.
R06	5×4 → 5×4	La lectura cruzada sigue funcionando a través de WAF y RASP (verificado). La heurística no bloquea.	La heurística aporta visibilidad (y tiene falsos positivos); no limita los datos expuestos.

ID	Inh. → Res.	Razón de P	Razón de I
R07	4×4 → 2×4	Una capa preventiva probada en el perímetro: P-2. Sin WAF la asignación sigue funcionando (escenario 2d, A7).	Una cuenta de administrador creada tendría la misma consecuencia.
R08	4×4 → 4×4	Sin control probado: el RASP solo cubre NoSQL de MongoDB y el CRS no se ejercitó en esta ruta.	Sin cambio.
R09	3×5 → 3×4	No hay control preventivo probado sobre eval/vm (el RASP instrumenta node:vm, pero no se ejercitó).	La escritura en el FS raíz está bloqueada (EROFS, probado en la Fase 5): sin persistencia ni modificación de binarios, I-1. La lectura de datos sigue siendo posible.
R10	3×5 → 3×5	Sin control probado.	Sin cambio.
R11	4×3 → 4×3	Sin control probado (la protección SSRF del RASP no se ejercitó).	Sin cambio.
R12	5×4 → 3×4	Una capa preventiva probada en el perímetro: P-2. Sin WAF los listados siguen expuestos (escenario 2d, A4-A5).	Sin cambio.
R13	4×4 → 4×4	La presencia de la cabecera CSP y de las reglas 941 no demuestra que los vectores XSS estén mitigados: no se ejercitó ningún vector.	Sin cambio.
R14	4×3 → 2×3	Una capa preventiva probada (la respuesta con Origin externo ya no lleva ACAO): P-2.	Sin cambio.
R15	4×3 → 4×3	Sin control probado.	Sin cambio.
R16	5×3 → 3×3	Una capa preventiva probada desde una IP: P-2. Un ataque distribuido desde muchas IP no está cubierto.	Sin cambio.
R17	5×2 → 3×2	El deny de nginx y el parche 100002 están en el MISMO componente (WAF): cuentan como una capa, P-2. Sin WAF, /metrics sigue abierto (2d, A6).	Sin cambio.
R18	3×4 → 3×4	Sin control preventivo probado.	Los límites están configurados (docker inspect) pero no se probó que absorban un ataque de disponibilidad.
R19	3×4 → 2×4	La centralización y la correlación están probadas: P-1 respecto de 3. No llega a 1: no hay notificación a personas, es de un solo nodo y se observó una interrupción de 11 minutos en la ingesta de contenedores durante la validación.	Sin cambio.
R20	4×5 → 4×5	Los escáneres identifican los componentes, no eliminan la vulnerabilidad.	Sin cambio.
R21	3×4 → 1×4	Evitación probada: no hay despliegue, así que el riesgo no puede materializarse HOY. Esto NO valida la seguridad de la infraestructura.	Sin cambio.
R22	5×3 → 2×3	Corregido y probado para los sinks de sqlite3 (403 en 0,04-0,15 s; disponibilidad 41/41; RestartCount 0). No llega a 1: los bloqueos en fs, http, child_process y vm no se probaron.	En los sinks no probados la consecuencia podría seguir siendo una caída.
R23	5×5 → 4×5	Se bloqueó la vía de SQLi (probado), pero la vía BOLA sigue abierta (probado): P-1.	La consecuencia legal y reputacional de una exposición no cambia; la transferencia solo está propuesta.
R24	2×5 → 2×3	Sin cambio de exposición (no hay puertos nuevos).	Contención probada: comprometer Alloy ya solo permite LEER metadatos y logs de contenedores (crear, detener o ejecutar responde 403), I-2. El proxy sí mantiene el socket: es el componente de confianza.

Nota. Elaboración propia con datos del repositorio del laboratorio.

2.6 Matriz de calor: probabilidad frente a impacto

Las figuras ubican cada riesgo según su probabilidad y su impacto antes (inherente) y después (residual) de los controles probados. El número de la esquina de cada celda es el producto P × I.

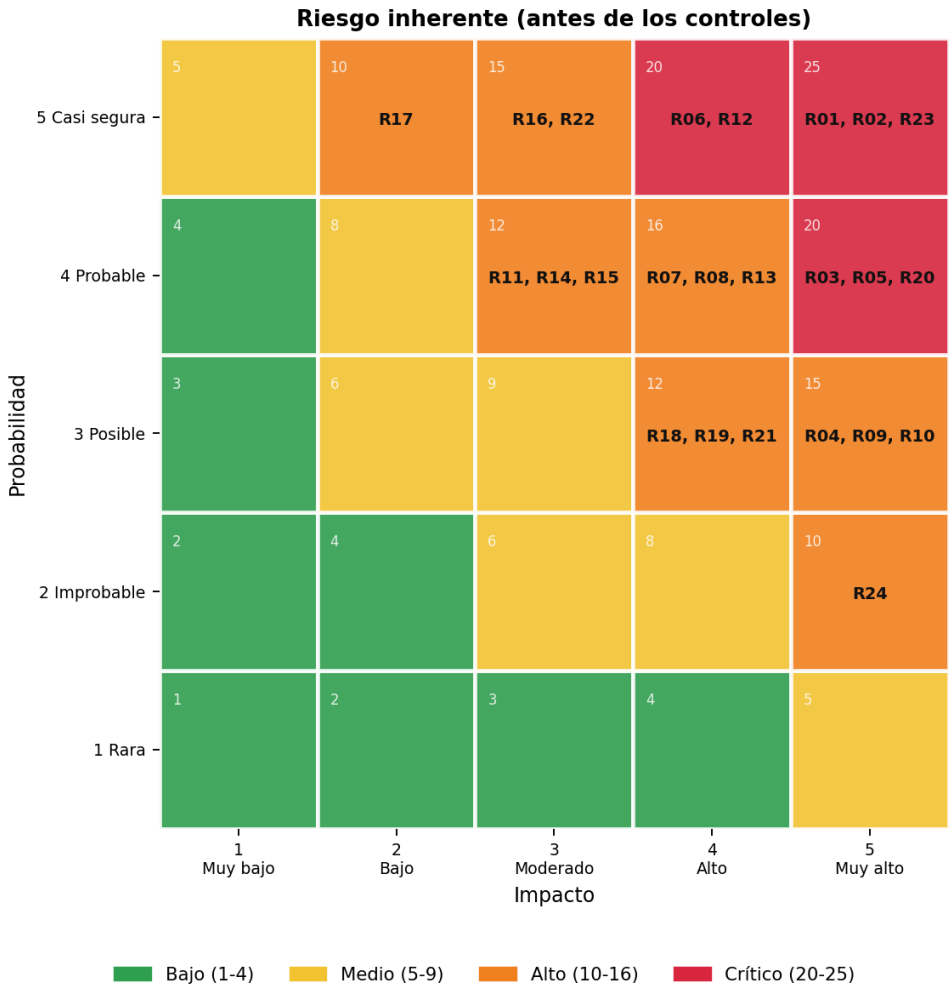


Figura 13. *Matriz de calor del riesgo inherente: 8 riesgos críticos y 16 altos.*

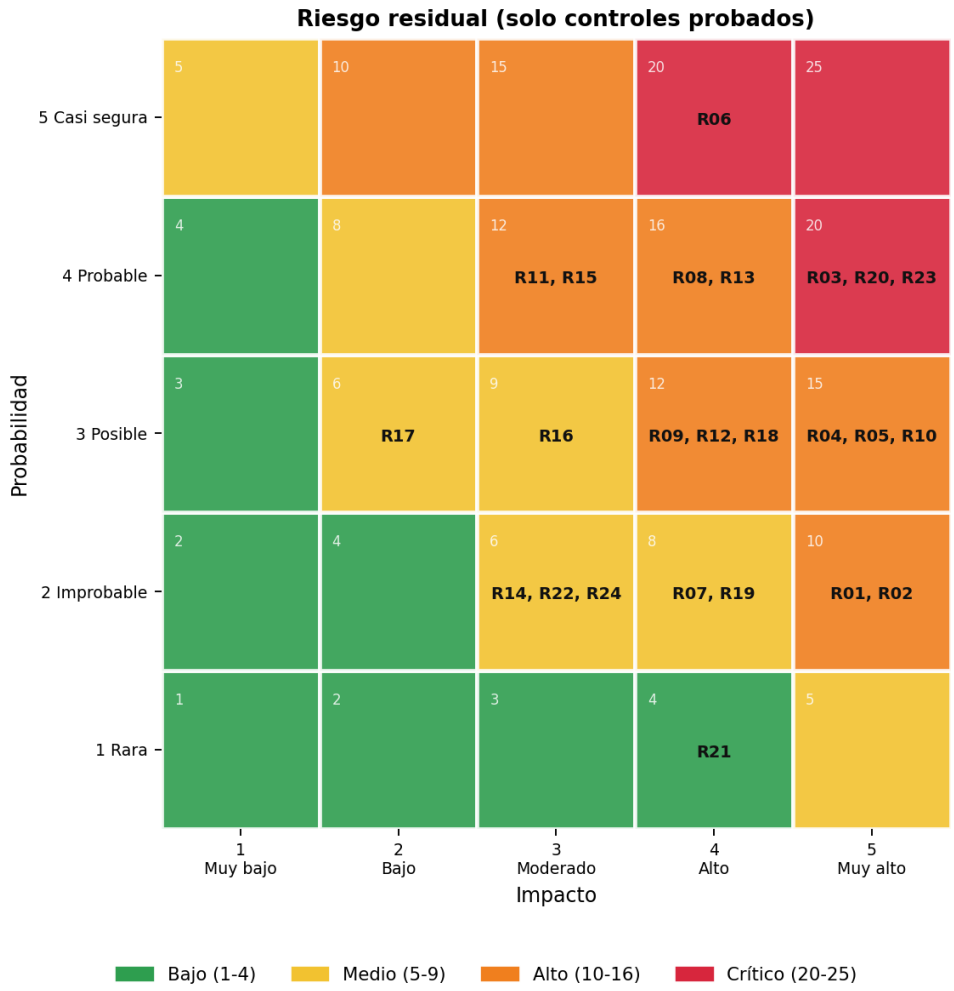


Figura 14. *Matriz de calor del riesgo residual (solo controles probados): 4 críticos (R03, R06, R20, R23), 12 altos, 7 medios y 1 bajo.*

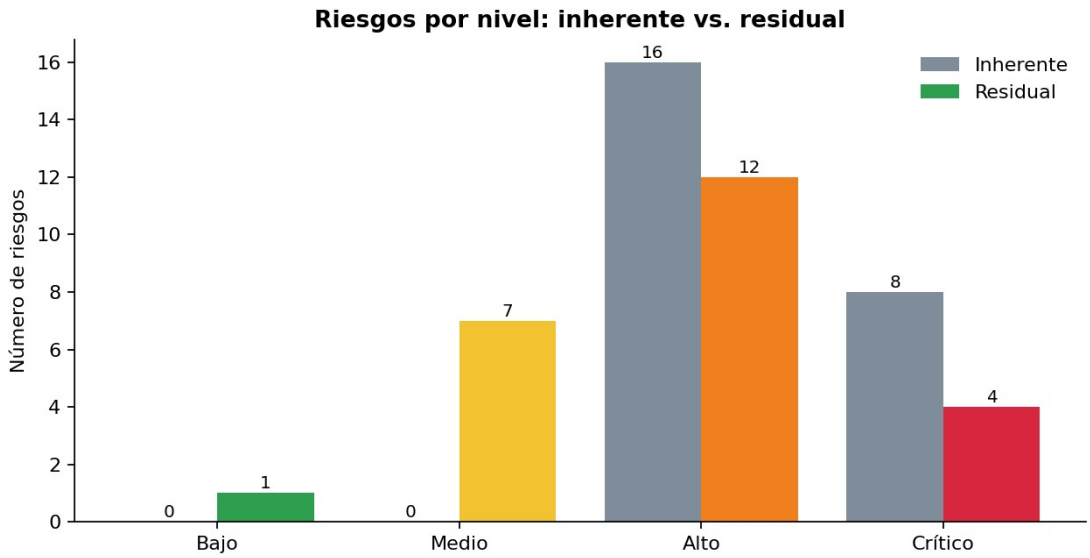


Figura 15. *Distribución de los 24 riesgos por nivel: inherente frente a residual.*

Tabla 12

Riesgos por nivel antes y después de los controles probados

Nivel	Inherente	Residual
Bajo	0	1
Medio	0	7
Alto	16	12
Crítico	8	4
Total	24	24

Nota. Elaboración propia con datos del repositorio del laboratorio.

2.7 Lectura del riesgo residual

- Quedan **4 riesgos críticos** (R03, R06, R20, R23) y **12 altos**. La mayoría depende de correcciones de código diseñadas o propuestas, no desplegadas, y por eso no recibe reducción.
- Los controles desplegados son sobre todo **compensatorios**: reducen la probabilidad de los vectores probados en el perímetro y en ejecución, pero no eliminan la causa. Por eso las inyecciones SQL (R01, R02) bajan de Crítico a Alto y no más: el impacto, si un ataque prospera, es el mismo.
- **R06 (BOLA)** sigue crítico: la lectura cruzada continúa con HTTP 200 a través del WAF y la heurística del SIEM no protege. **R03** sigue crítico porque ningún control detecta un token forjado.

- **R21** es Bajo solo porque la nube no está desplegada (evitación probada); eso no valida la seguridad de la infraestructura, que debería probarse en ejecución antes de desplegar.
- **R22** y **R24** son riesgos introducidos por los propios controles. Se identificaron, se trataron y se verificaron dentro de la fase: un control nuevo también es una fuente de riesgo.

Limitaciones y pendientes

- Parches 01-08 diseñados, no desplegados: la aplicación no se recompiló. Son la vía para reducir R01-R03, R05-R07, R09 y R14 y para cerrar el BOLA.
- WAF: solo la familia de inyección SQL está probada; XSS, RCE, LFI y fugas en respuestas están configuradas, sin prueba. La exclusión de la regla 920350 es una recomendación.
- RASP: los bloqueos en sinks distintos de `sqlite3` no se probaron; la respuesta 403 incluye la traza de pila del manejador de errores de Juice Shop.
- Monitoreo de API: la heurística BOLA tiene falsos positivos (demostrado) y falsos negativos (por análisis); la regla de 5xx no se validó con una ráfaga real.
- SIEM: un solo nodo, sin autenticación en Loki, sin notificaciones externas y sin alerta por pérdida de ingesta; el proxy del socket sigue siendo un componente de confianza.
- Nube (Fase 2): diseñada y validada estáticamente (plan sin conexión y Checkov), no desplegada; su seguridad en ejecución no está verificada.
- Documento: este archivo es un borrador de validación; la carátula institucional (logo oficial de la UMG) y la maquetación final las integra el equipo.

Conclusiones

La Fase 6 integró y validó una estrategia de defensa en profundidad con evidencia reproducible. El WAF neutralizó las once condiciones del arnés sin bloquear el tráfico legítimo. El RASP, con una integración que corrige un defecto de disponibilidad, bloquea las inyecciones SQL con HTTP 403 incluso con el perímetro evadido. El SIEM centraliza y correlaciona los eventos de las tres fuentes y activó cinco de siete reglas a través del WAF, más la del RASP cuando la aplicación se atacó directamente.

La validación también demostró lo que los controles no hacen. El BOLA sigue abierto a través de todas las capas; la heurística de API produce falsos positivos; y la protección de la nube es solo de diseño. Operar los controles reveló además defectos que solo aparecen en funcionamiento: el bloqueo del RASP provocaba la caída del proceso o dejaba peticiones colgadas, el healthcheck del WAF lo marcaba como no

saludable, el montaje de solo lectura del socket de Docker no protegía su API y el propio SIEM perdió la ingesta durante minutos. Todos se corrigieron o quedaron documentados con evidencia.

El tratamiento formal, con el residual justificado riesgo por riesgo y validado automáticamente, reduce los críticos de 8 a 4 y los altos de 16 a 12. Es una reducción menor que la de una lectura optimista, pero defendible: el riesgo crítico restante depende de correcciones de código diseñadas y no desplegadas, que son la prioridad del trabajo siguiente.

Referencias

Aikido Security. (2026). Zen for Node.js (Versión 1.8.46) [Software]. https://github.com/AikidoSec/firewall-node

Grafana Labs. (s. f.-a). Grafana Alloy documentation. https://grafana.com/docs/alloy/latest/

Grafana Labs. (s. f.-b). Grafana Loki documentation. https://grafana.com/docs/loki/latest/

International Organization for Standardization. (2022). Information security, cybersecurity and privacy protection — Guidance on managing information security risks (ISO/IEC 27005:2022).

Kent, K., y Souppaya, M. (2006). Guide to computer security log management (NIST Special Publication 800-92). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-92

Kimminich, B. (2026). OWASP Juice Shop (Versión 20.3.0) [Software]. OWASP Foundation. https://github.com/juice-shop/juice-shop

MITRE Corporation. (s. f.). CWE: Common Weakness Enumeration. https://cwe.mitre.org/

OWASP CRS Project. (s. f.). OWASP CRS (Versión 4.25.2) [Software]. https://coreruleset.org/

OWASP Foundation. (2023). OWASP API Security Top 10 – 2023. https://owasp.org/API-Security/editions/2023/en/0x11-t10/

OWASP Foundation. (2025). OWASP Top 10:2025. https://owasp.org/Top10/2025/

OWASP Foundation. (s. f.). ModSecurity (Versión 3.0.17) [Software]. https://github.com/owasp-modsecurity/ModSecurity

Tecnativa. (s. f.). docker-socket-proxy (Versión 0.4.1) [Software]. https://github.com/Tecnativa/docker-socket-proxy

Anexos

Anexo A. Integridad de la evidencia de la Fase 6

Extracto de `evidence/MANIFEST.sha256` (244 archivos de la Fase 6). Por espacio se muestran los primeros 16 caracteres de cada SHA-256; el valor completo está en el manifiesto y se verifica con `sha256sum -c MANIFEST.sha256` desde `evidence/`. El manifiesto solo incluye archivos versionados.

```
3169e53e998197ae…  fase-6/defensa-completa/a1-sqli-login.json
e38857a6b47114d6…  fase-6/defensa-completa/a10-bruteforce-login.txt
3169e53e998197ae…  fase-6/defensa-completa/a11-jwt-key.txt
3169e53e998197ae…  fase-6/defensa-completa/a2-sqli-union-search.json
3169e53e998197ae…  fase-6/defensa-completa/a3-sqli-schema.json
c5bcadc3d788fd46…  fase-6/defensa-completa/a4-directory-listing.txt
3169e53e998197ae…  fase-6/defensa-completa/a5-acquisitions.md
3169e53e998197ae…  fase-6/defensa-completa/a6-metrics.txt
3169e53e998197ae…  fase-6/defensa-completa/a7-mass-assignment.json
0bf376bdd1061475…  fase-6/defensa-completa/a8-cors-headers.txt
ce5c80171b4a5618…  fase-6/defensa-completa/a9-security-headers.txt
ae4ae70c0987abbe…  fase-6/defensa-completa/bola/cross-read.json
2d45e62c8d646458…  fase-6/defensa-completa/bola/own-read.json
c0225e8552fa52d8…  fase-6/defensa-completa/bola/resultado-bola.md
0a6731f547e125c6…  fase-6/defensa-completa/resumen-ataques.md
970a8db47dba2b0c…  fase-6/funcional/trafico-legitimo.txt
630b1744e8947bee…  fase-6/rasp/01-deteccion-sin-bloqueo/LEAME-redaccion.md
9850c363016b0bf1…  fase-6/rasp/01-deteccion-sin-bloqueo/a1-sqli-login.json
e414041ef042e8cd…  fase-6/rasp/01-deteccion-sin-bloqueo/a10-bruteforce-login.txt
89fdb7cbbc50749d…  fase-6/rasp/01-deteccion-sin-bloqueo/a11-jwt-key.txt
f199526fada1a39d…  fase-6/rasp/01-deteccion-sin-bloqueo/a2-sqli-union-search.json
9098cfa7a99ad97c…  fase-6/rasp/01-deteccion-sin-bloqueo/a3-sqli-schema.json
be86b35a56b7a04a…  fase-6/rasp/01-deteccion-sin-bloqueo/a4-directory-listing.txt
48321ee73b6b6de8…  fase-6/rasp/01-deteccion-sin-bloqueo/a5-acquisitions.md
bf1fdcaab7784b19…  fase-6/rasp/01-deteccion-sin-bloqueo/a6-metrics.txt
3d3a221a79343e9a…  fase-6/rasp/01-deteccion-sin-bloqueo/a7-mass-assignment.json
f5716a40a631f588…  fase-6/rasp/01-deteccion-sin-bloqueo/a8-cors-headers.txt
ea5b4efe4dee6201…  fase-6/rasp/01-deteccion-sin-bloqueo/a9-security-headers.txt
ace1cea8ef9bc396…  fase-6/rasp/01-deteccion-sin-bloqueo/bola/cross-read.json
b78208233c619a3f…  fase-6/rasp/01-deteccion-sin-bloqueo/bola/own-read.json
86ce308979e34706…  fase-6/rasp/01-deteccion-sin-bloqueo/bola/resultado-bola.md
9b5a45747883d65c…  fase-6/rasp/01-deteccion-sin-bloqueo/rasp-detecciones.log
72a0dc2cd998fe61…  fase-6/rasp/01-deteccion-sin-bloqueo/resumen-ataques.md
8fb6b1a12c84f368…  fase-6/rasp/02-bloqueo-caida-del-proceso/LEAME-corrida-invalida.md
01ba4719c80b6fe9…  fase-6/rasp/02-bloqueo-caida-del-proceso/a1-sqli-login.json
e4fb5b1c0a82f9b4…  fase-6/rasp/02-bloqueo-caida-del-proceso/a10-bruteforce-login.txt
01ba4719c80b6fe9…  fase-6/rasp/02-bloqueo-caida-del-proceso/a2-sqli-union-search.json
01ba4719c80b6fe9…  fase-6/rasp/02-bloqueo-caida-del-proceso/a3-sqli-schema.json
b316166563fa1b01…  fase-6/rasp/02-bloqueo-caida-del-proceso/a4-directory-listing.txt
01ba4719c80b6fe9…  fase-6/rasp/02-bloqueo-caida-del-proceso/a7-mass-assignment.json
01ba4719c80b6fe9…  fase-6/rasp/02-bloqueo-caida-del-proceso/a8-cors-headers.txt
01ba4719c80b6fe9…  fase-6/rasp/02-bloqueo-caida-del-proceso/a9-security-headers.txt
b1f15e6d23ce0415…  fase-6/rasp/02-bloqueo-caida-del-proceso/bola/resultado-bola.md
4a57b13fba3e2f67…  fase-6/rasp/02-bloqueo-caida-del-proceso/rasp-caida.log
a35d585bf06d78d6…  fase-6/rasp/02-bloqueo-caida-del-proceso/resumen-ataques.md
01ba4719c80b6fe9…  fase-6/rasp/03-bloqueo-sin-caida/a1-sqli-login.json
e414041ef042e8cd…  fase-6/rasp/03-bloqueo-sin-caida/a10-bruteforce-login.txt
89fdb7cbbc50749d…  fase-6/rasp/03-bloqueo-sin-caida/a11-jwt-key.txt
01ba4719c80b6fe9…  fase-6/rasp/03-bloqueo-sin-caida/a2-sqli-union-search.json
01ba4719c80b6fe9…  fase-6/rasp/03-bloqueo-sin-caida/a3-sqli-schema.json
be86b35a56b7a04a…  fase-6/rasp/03-bloqueo-sin-caida/a4-directory-listing.txt
48321ee73b6b6de8…  fase-6/rasp/03-bloqueo-sin-caida/a5-acquisitions.md
d2fc092c0b6f4040…  fase-6/rasp/03-bloqueo-sin-caida/a6-metrics.txt
449b63a3d459a483…  fase-6/rasp/03-bloqueo-sin-caida/a7-mass-assignment.json
92a50789cc1c0cad…  fase-6/rasp/03-bloqueo-sin-caida/a8-cors-headers.txt
05eea9e11d58b36a…  fase-6/rasp/03-bloqueo-sin-caida/a9-security-headers.txt
e095959c7ce74385…  fase-6/rasp/03-bloqueo-sin-caida/bola/cross-read.json
43b65b8f836e080a…  fase-6/rasp/03-bloqueo-sin-caida/bola/own-read.json
9237b1d5d5016f15…  fase-6/rasp/03-bloqueo-sin-caida/bola/resultado-bola.md
39fa0192847aa1ec…  fase-6/rasp/03-bloqueo-sin-caida/rasp-bloqueos.log
7ba83ad55c559969…  fase-6/rasp/03-bloqueo-sin-caida/resumen-ataques.md
66f0e64af2c6b3db…  fase-6/rasp/arranque-agente.log
c8238fe995170f1a…  fase-6/siem/alertas-tras-defensa-completa.json
fdb175fb4d025791…  fase-6/siem/alertas-tras-prueba-rasp.json
e3d23c8f35959d3f…  fase-6/siem/capturas/grafana-dashboard-siem.png
de05b84809f43dac…  fase-6/siem/consultas-logql-resumen.txt
8d8275b4b5a9a8dc…  fase-6/siem/consultas-logql.jsonl
2d8a3af006826ea8…  fase-6/siem/reglas-estado-resumen.txt
bf84e1444fb62233…  fase-6/siem/reglas-estado.json
3e76dee98e16aea3…  fase-6/siem/stack-docker-ps.txt
9a167c1150e3b49f…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/LEAME.md
474de01a64858edb…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a1-sqli-login.json
e414041ef042e8cd…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a10-bruteforce-login.txt
89fdb7cbbc50749d…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a11-jwt-key.txt
e1e59a7fb9d4975c…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a2-sqli-union-search.json
```

```
339a8620f2bd5b12…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a3-sqli-schema.json
be86b35a56b7a04a…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a4-directory-listing.txt
48321ee73b6b6de8…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a5-acquisitions.md
fdde654a26bf9391…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a6-metrics.txt
24a9bdda006ed8dc…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a7-mass-assignment.json
e34f9367cfe78b41…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a8-cors-headers.txt
48dd9e420971d1b0…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/a9-security-headers.txt
4bb8d891d130896b…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/bola/cross-read.json
8128dbba0a03374c…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/bola/own-read.json
b4f3ddb868fcb237…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/bola/resultado-bola.md
3a39c316718fc6c4…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/consola.txt
c4df639945d4f83c…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/http.tsv
bd340dd3e43be148…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/resumen-ataques.md
9850c363016b0bf1…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a1-sqli-login.json
e414041ef042e8cd…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a10-bruteforce-login.txt
89fdb7cbbc50749d…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a11-jwt-key.txt
f199526fada1a39d…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a2-sqli-union-search.json
9098cfa7a99ad97c…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a3-sqli-schema.json
be86b35a56b7a04a…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a4-directory-listing.txt
48321ee73b6b6de8…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a5-acquisitions.md
e620bffa07e41741…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a6-metrics.txt
0c89eee5ae4bb9d9…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a7-mass-assignment.json
3831ea8da10bba02…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a8-cors-headers.txt
10879ee2a43a69a9…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/a9-security-headers.txt
46844557ff8c080b…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/bola/cross-read.json
418778cf6f6e05e4…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/bola/own-read.json
7bc6a67d7030f934…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/bola/resultado-bola.md
3a39c316718fc6c4…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/consola.txt
b76295fe674196b2…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/http.tsv
c6e01ad047b1f413…  fase-6/validacion-2026-11-10/01-linea-base-vulnerable/resumen-ataques.md
9850c363016b0bf1…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a1-sqli-login.json
e414041ef042e8cd…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a10-bruteforce-login.txt
89fdb7cbbc50749d…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a11-jwt-key.txt
f199526fada1a39d…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a2-sqli-union-search.json
9098cfa7a99ad97c…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a3-sqli-schema.json
be86b35a56b7a04a…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a4-directory-listing.txt
48321ee73b6b6de8…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a5-acquisitions.md
2a8d216b5a7f96b9…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a6-metrics.txt
dc05b5bb767e7ef6…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a7-mass-assignment.json
7f94a3d5bd1b568e…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a8-cors-headers.txt
7f4ea5ee8a33a31c…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/a9-security-headers.txt
6837274efae313e8…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/bola/cross-read.json
5ebdf334150180b1…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/bola/own-read.json
5321c501b5a1518b…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/bola/resultado-bola.md
2f63435ddd4f9869…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/consola.txt
2a7cd4691e7e65c3…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/disponibilidad.tsv
5852b1158e479602…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/estado-contenedor.txt
6c26eb4c81efa066…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/http.tsv
f4bbb0ce3f6a11df…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/rasp.log
0e220a1048de09a0…  fase-6/validacion-2026-11-10/02a-rasp-monitoreo/resumen-ataques.md
ca026c65e605203e…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/LEAME-no-es-mitigacion.md
01ba4719c80b6fe9…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/a1-sqli-login.json
e4fb5b1c0a82f9b4…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/a10-bruteforce-login.txt
01ba4719c80b6fe9…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/a2-sqli-union-search.json
01ba4719c80b6fe9…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/a3-sqli-schema.json
b316166563fa1b01…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/a4-directory-listing.txt
01ba4719c80b6fe9…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/a7-mass-assignment.json
01ba4719c80b6fe9…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/a8-cors-headers.txt
01ba4719c80b6fe9…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/a9-security-headers.txt
c24583798832a69c…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/bola/resultado-bola.md
2010b1e784afb996…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/consola.txt
7f8378d4626d2872…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/disponibilidad.tsv
ae27e418c5bb9787…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/estado-contenedor.txt
8bd33733daadb681…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/http.tsv
75daec727191f954…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/rasp.log
e5ebacaceb7707ee…  fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/resumen-ataques.md
c9a48e885b503304…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/LEAME-no-es-mitigacion.md
01ba4719c80b6fe9…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a1-sqli-login.json
e414041ef042e8cd…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a10-bruteforce-login.txt
89fdb7cbbc50749d…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a11-jwt-key.txt
01ba4719c80b6fe9…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a2-sqli-union-search.json
01ba4719c80b6fe9…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a3-sqli-schema.json
be86b35a56b7a04a…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a4-directory-listing.txt
48321ee73b6b6de8…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a5-acquisitions.md
f7275ff18e36c32a…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a6-metrics.txt
586bb9c0682870d8…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a7-mass-assignment.json
0c1f1438a7381858…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a8-cors-headers.txt
60b9205d2f001aa6…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/a9-security-headers.txt
eb9c250674d5f00d…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/bola/cross-read.json
61d0f43a15d231d7…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/bola/own-read.json
0ca5a04ab85abb7f…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/bola/resultado-bola.md
cfc8bdd45df16a5d…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/consola.txt
e4a3da682691c760…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/disponibilidad.tsv
98e9314835a57eb7…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/estado-contenedor.txt
25858203ae4c0e9b…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/http.tsv
8d881a6e6d1dec4f…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/rasp.log
52d83ffaf660037b…  fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/resumen-ataques.md
96b24bea107c66f8…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a1-sqli-login.json
e414041ef042e8cd…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a10-bruteforce-login.txt
89fdb7cbbc50749d…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a11-jwt-key.txt
adad4e4a32ba6d33…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a2-sqli-union-search.json
adad4e4a32ba6d33…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a3-sqli-schema.json
be86b35a56b7a04a…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a4-directory-listing.txt
48321ee73b6b6de8…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a5-acquisitions.md
fdd872c2118172f8…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a6-metrics.txt
2fa99abc76b5c4cd…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a7-mass-assignment.json
```

```
10d4a08c47e9ecd4…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a8-cors-headers.txt
850c2103e9fadad5…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/a9-security-headers.txt
9cf8d8d98dd3706a…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/bola/cross-read.json
87eeb3b3b3e9cedc…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/bola/own-read.json
7f9a774026e91868…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/bola/resultado-bola.md
b6957c5f0865ebc4…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/consola.txt
e4c25631833ba393…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/disponibilidad.tsv
49560152f6717d08…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/estado-contenedor.txt
b93cddf164f46e6e…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/http.tsv
64320c989e4ed9c8…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/rasp.log
ea1a7395374ef765…  fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/resumen-ataques.md
3169e53e998197ae…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a1-sqli-login.json
e38857a6b47114d6…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a10-bruteforce-login.txt
3169e53e998197ae…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a11-jwt-key.txt
3169e53e998197ae…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a2-sqli-union-search.json
3169e53e998197ae…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a3-sqli-schema.json
c5bcadc3d788fd46…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a4-directory-listing.txt
3169e53e998197ae…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a5-acquisitions.md
3169e53e998197ae…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a6-metrics.txt
3169e53e998197ae…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a7-mass-assignment.json
260b4ad72c9e928e…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a8-cors-headers.txt
1a915a99cd284216…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/a9-security-headers.txt
d21f6694c523106d…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/alertas.json
83772525508d0111…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/bola/cross-read.json
cf11caa7733f6987…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/bola/own-read.json
d1a23d0645ccb300…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/bola/resultado-bola.md
7be3fc99d1236b29…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/capturas/grafana-dashboard-siem.png
b9024a8a5ffe2505…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/consola.txt
c4e471d38fc80009…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/consultas-logql.txt
0c9dfef2e5576e0b…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/estado-contenedores.txt
e29ab52e0c4b912c…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/http.tsv
69503a6421cfa641…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/logs-waf/modsec-audit.redactado.log
58ebf3b512fb87dc…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/logs-waf/waf-access.log
e90ff18c09c49600…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/reglas-estado.json
1709ce775c751e95…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/resumen-ataques.md
8a74327ac17541c6…  fase-6/validacion-2026-11-10/03-waf-rasp-siem/trafico-legitimo-posterior.txt
96b24bea107c66f8…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a1-sqli-login.json
e414041ef042e8cd…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a10-bruteforce-login.txt
89fdb7cbbc50749d…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a11-jwt-key.txt
adad4e4a32ba6d33…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a2-sqli-union-search.json
adad4e4a32ba6d33…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a3-sqli-schema.json
be86b35a56b7a04a…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a4-directory-listing.txt
48321ee73b6b6de8…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a5-acquisitions.md
17f1d88a366b52cc…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a6-metrics.txt
eaadab5d8682aa81…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a7-mass-assignment.json
7f2ff3065facfd39…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a8-cors-headers.txt
dcc3ffd57f1f57dc…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/a9-security-headers.txt
d8a263d55a925b9c…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/alertas.json
fba90e10e84e21e1…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/bola/cross-read.json
8975dda5a3d746a3…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/bola/own-read.json
aee25fabf7b8966c…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/bola/resultado-bola.md
403beed9e0f6c301…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/consola.txt
7ab2da48a14d92d9…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/disponibilidad.tsv
10724fa113bc93c9…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/estado-contenedor.txt
2590fcd6d1b629e8…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/http.tsv
1fa1a221e9b7c191…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/loki-rasp.txt
64320c989e4ed9c8…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/rasp.log
a4e1f1e09dfdd225…  fase-6/validacion-2026-11-10/03b-rasp-a-siem/resumen-ataques.md
acd2c2e20926b8cf…  fase-6/validacion-2026-11-10/04-falsos-positivos/alertas-tras-trafico-legitimo.json
849d29f5e05aa103…  fase-6/validacion-2026-11-10/04-falsos-positivos/trafico-legitimo.txt
17ccbbf7bbf2c5af…  fase-6/validacion-2026-11-10/05-siem-seguridad/proxy-socket-api.txt
058ba105d96e895e…  fase-6/validacion-2026-11-10/05-siem-seguridad/stack-docker-ps.txt
374db5178a19ba83…  fase-6/validacion-2026-11-10/06-cloud-no-desplegado.txt
db4e414e4b198a9d…  fase-6/validacion-2026-11-10/07-parches-apply-check.txt
9a1920999a8a8f94…  fase-6/validacion-2026-11-10/LEAME-redaccion.md
827b14d901b55472…  fase-6/validacion-2026-11-10/LEAME.md
1913d8006853b5ed…  fase-6/validacion-2026-11-10/resumen-r22.txt
a43d821691f28b73…  fase-6/validacion-2026-11-10/resumen-siem-reglas.txt
598b4da7f56ecdcc…  fase-6/waf-logs/fase6-2026-11-10/modsec-audit.redactado.log
7c6c5e9986225ef2…  fase-6/waf-logs/fase6-2026-11-10/waf-access.log
d62780de813bb1a3…  fase-6/waf-logs/modsec-audit.log
878693409d38b91f…  fase-6/waf-logs/resumen-bloqueos.md
876b9f8ddf60327e…  fase-6/waf/crs-inventario.txt
```

Anexo B. Bitácora de comandos de la Fase 6

Entradas de `evidence/bitacora.md` con fase 6 (fecha, comando, herramienta y resultado). Las entradas «CORRECCIÓN» documentan corridas cuyos resultados del arnés no son mitigaciones.

2026-11-10T21:33:34-06:00 · `docker compose -f docker-compose.yml -f docker-compose.ops.yml up -d --build` (`WAF_PORT=8088`) · WAF CRS 4.25.2/ModSecurity 3.0.17; Aikido Zen 1.8.46; Loki 3.5.5, Alloy v1.10.2, Grafana 12.1.1 · Stack de operaciones arriba solo en 127.0.0.1 (WAF 8088 porque 8080 lo ocupa un proceso javaw del equipo; Grafana 3001; Loki 3100). RASP sin token: sin reporte externo.

2026-11-10T21:33:34-06:00 · `trafico legitimo via WAF+RASP (control de falsos positivos)` · curl · 6/6 peticiones legitimas 200/201 (busqueda, registro sin role, login, cesta propia). evidence/fase-6/funcional/trafico-legitimo.txt

2026-11-10T21:33:34-06:00 · `run.sh directo a juice-hardened:3000, RASP AIKIDO_BLOCK=false (sin WAF)` · Aikido Zen 1.8.46 · Modo monitoreo: 3 SQLi detectadas (body.email, query.q x2) en sqlite3.all; ataques no bloqueados (esperado). evidence/fase-6/rasp/01-deteccion-sin-bloqueo/

2026-11-10T21:33:35-06:00 · `CORRECCION de la entrada rasp-bloqueo (21:24:46): corrida INVALIDA` · Aikido Zen 1.8.46 · El primer bloqueo hizo terminar el proceso Node (rechazo no manejado, RestartCount=1); los MITIGADO fueron HTTP 000. Carpeta renombrada a evidence/fase-6/rasp/02-bloqueo-caida-del-proceso/ (ver LEAME)

2026-11-10T21:33:35-06:00 · `run.sh directo, RASP AIKIDO_BLOCK=true + --unhandled-rejections=warn (sin WAF)` · Aikido Zen 1.8.46, Node 24.21.0 · A1-A3 bloqueadas por el RASP sin caida del proceso (RestartCount 0); resto vulnerable sin WAF (fuera del alcance del RASP). evidence/fase-6/rasp/03-bloqueo-sin-caida/

2026-11-10T21:33:35-06:00 · `run.sh via WAF 127.0.0.1:8088 con RASP (defensa completa, A12_DELAY=65)` · WAF + RASP · A1-A11 MITIGADO (11/11); A12 BOLA sigue VULNERABLE a traves del WAF (B leyo cesta de A, HTTP 200): el WAF no controla propiedad de objetos. evidence/fase-6/defensa-completa/

2026-11-10T21:33:35-06:00 · `Loki ruler /prometheus/api/v1/rules y LogQL` · Loki 3.5.5 · 6/7 reglas firing (SQLi WAF, parche virtual, fuerza bruta 429, rutas sensibles, enumeracion BOLA, RASP); App_Errores_5xx inactiva. evidence/fase-6/siem/

2026-11-10T21:44:01-06:00 · `healthcheck del WAF: imagen probaba https://localhost:8443/healthz (no servido) -> override HTTP 8080/healthz` · Docker 29.9.2, owasp/modsecurity-crs 4.25.2 · juice-waf pasa de unhealthy a healthy; trafico sin cambios. deploy/hardened/docker-compose.yml

2026-11-10T21:52:56-06:00 · `node build.js (2 pasadas: indice con paginas reales leidas del PDF) + soffice --convert-to pdf` · docx 9.5.1 (Node 24, Docker), LibreOffice, poppler pdftotext · Entregable Word+PDF de la Fase 6: 32 paginas, 15 figuras, 8 tablas, anexos con MANIFEST y bitacora. docs/fase-6/entregable/

2026-11-10T22:58:34-06:00 · `security/attacks/run.sh (http://juice-hardened:3000, 02a-rasp-monitoreo)` · curl + código del laboratorio · A1-A11: 11 VULNERABLE / 0 MITIGADO de 11; A12 BOLA: VULNERABLE. evidence/fase-6/validacion-2026-11-10/02a-rasp-monitoreo/resumen-ataques.md

2026-11-10T22:59:12-06:00 · `security/attacks/run.sh (http://juice-hardened:3000, 02b-rasp-bloqueo-sin-integracion)` · curl + código del laboratorio · A1-A11: 2 VULNERABLE / 9 MITIGADO de 11; A12 BOLA: MITIGADO/NEGATIVO. evidence/fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/resumen-ataques.md

2026-11-10T23:02:15-06:00 · `security/attacks/run.sh (http://juice-hardened:3000, 02c-rasp-bloqueo-warn)` · curl + código del laboratorio · A1-A11: 8 VULNERABLE / 3 MITIGADO de 11; A12 BOLA: VULNERABLE. evidence/fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/resumen-ataques.md

2026-11-10T23:03:41-06:00 · `security/attacks/run.sh (http://juice-hardened:3000, 02d-rasp-bloqueo-integrado)` · curl + código del laboratorio · A1-A11: 8 VULNERABLE / 3 MITIGADO de 11; A12 BOLA: VULNERABLE. evidence/fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/resumen-ataques.md

2026-11-10T23:10:12-06:00 · `security/attacks/run.sh (http://127.0.0.1:3000, 01-linea-base-vulnerable)` · curl + código del laboratorio · A1-A11: 11 VULNERABLE / 0 MITIGADO de 11; A12 BOLA: VULNERABLE. evidence/fase-6/validacion-2026-11-10/01-linea-base-vulnerable/resumen-ataques.md

2026-11-10T23:11:32-06:00 · `security/attacks/run.sh (http://127.0.0.1:3000, 01-linea-base-vulnerable)` · curl + código del laboratorio · A1-A11: 11 VULNERABLE / 0 MITIGADO de 11; A12 BOLA: VULNERABLE. evidence/fase-6/validacion-2026-11-10/01-linea-base-vulnerable/resumen-ataques.md

2026-11-10T23:15:18-06:00 · `security/attacks/run.sh (http://127.0.0.1:8088, 03-waf-rasp-siem)` · curl + código del laboratorio · A1-A11: 0 VULNERABLE / 11 MITIGADO de 11; A12 BOLA: VULNERABLE. evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/resumen-ataques.md

2026-11-10T23:17:35-06:00 · `security/attacks/run.sh (http://juice-hardened:3000, 03b-rasp-a-siem)` · curl + código del laboratorio · A1-A11: 8 VULNERABLE / 3 MITIGADO de 11; A12 BOLA: VULNERABLE. evidence/fase-6/validacion-2026-11-10/03b-rasp-a-siem/resumen-ataques.md

2026-11-10T23:32:16-06:00 · `CORRECCION de la entrada 22:59:12 (02b-rasp-bloqueo-sin-integracion)` · Aikido Zen 1.8.46, Node 24.21.0 · Los 9 MITIGADO y A12 MITIGADO/NEGATIVO NO son mitigaciones: el primer bloqueo termino el proceso (RestartCount 0->1; 000; sonda 1/6). Evidencia del riesgo R22. evidence/fase-6/validacion-2026-11-10/02b-rasp-bloqueo-sin-integracion/LEAME-no-es-mitigacion.md

2026-11-10T23:32:16-06:00 · `CORRECCION de la entrada 23:02:15 (02c-rasp-bloqueo-warn)` · Aikido Zen 1.8.46, Node 24.21.0 · Los 3 MITIGADO de A1-A3 son timeouts (000 a los 20 s), no bloqueos: --unhandled-rejections=warn solo evita la caida (106/106). evidence/fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/LEAME-no-es-mitigacion.md

2026-11-10T23:32:16-06:00 · `CORRECCION de la entrada 23:10:12 (linea base, intento 1)` · curl.exe 8.23 (Git Bash) · Resultados validos pero http.tsv vacio (curl.exe no entiende rutas /c/...); carpeta renombrada a evidence/fase-6/validacion-2026-11-10/01-linea-base-vulnerable-intento1/ y corrida repetida (23:11:32)

2026-11-10T23:32:16-06:00 · `integracion rasp-guard.js (bloqueo del RASP -> error por callback + HTTP 403) en Dockerfile.rasp` · Aikido Zen 1.8.46, sequelize sqlite query.js:183 · Bloqueo en 0,04-0,15 s con 403, disponibilidad 41/41, RestartCount 0 (02d y 03b). evidence/fase-6/validacion-2026-11-10/resumen-r22.txt

2026-11-10T23:32:16-06:00 · `docker-socket-proxy (solo lectura) + Alloy uid 473 sin socket; prueba de API desde la red interna` · tecnativa/docker-socket-proxy v0.4.1, Alloy v1.10.2 · GET _ping/version/containers/networks 200; POST create/stop/exec, DELETE, POST images/create 403. Ingesta interrumpida ~11 min (GET /networks denegado) y corregida. evidence/fase-6/validacion-2026-11-10/05-siem-seguridad/proxy-socket-api.txt

2026-11-10T23:32:16-06:00 · `security/ops/trafico-legitimo.sh http://127.0.0.1:8088 (2 usuarios)` · curl · 9 operaciones correctas (7 con 200/201, 2 logins con token); heuristica BOLA en firing = FALSO POSITIVO. evidence/fase-6/validacion-2026-11-10/04-falsos-positivos/

2026-11-10T23:32:16-06:00 · `Loki /prometheus/api/v1/rules y LogQL (escenarios 3 y 3b)` · Loki 3.5.5 · Escenario 3: 5/7 firing (RASP inactive: el WAF freno la SQLi); 3b: RASP_Ataque_Detectado firing con 6 lineas en Loki. evidence/fase-6/validacion-2026-11-10/resumen-siem-reglas.txt

2026-11-10T23:32:16-06:00 · `make risk (riesgo.py + generar_md.py), prueba negativa del validador` · Python 3.12, matplotlib 3.9.2 · 301 validaciones OK; prueba negativa rechaza reducciones sin control probado (exit 1). Residual: Critico 8->4, Alto 16->12, Medio 0->7, Bajo 0->1

2026-11-10T23:42:04-06:00 · `node build.js (borrador de validacion, 2 pasadas) + soffice --convert-to pdf; verificacion de enlaces y fuentes` · docx 9.5.1, LibreOffice, poppler, pypdf 5.1.0 · BORRADOR_VALIDACION_Fase6 (37 p., 15 figuras, 12 tablas): 22 hipervinculos internos (DOCX y PDF), Anexo A = MANIFEST (243/243), fuentes Liberation Sans/Mono. El entregable institucional NO se sobrescribio.

2026-11-10T23:42:04-06:00 · `git apply --check app-hardened/patches/0*.patch` · git · 7/8 aplican; 04 manual a proposito (clave no versionada). Estado: disenado (app no recompilada). evidence/fase-6/validacion-2026-11-10/07-parches-apply-check.txt

Anexo C. Reglas de correlación del SIEM (LogQL)

Contenido de `deploy/hardened/siem/rules/fake/alertas.yaml`, evaluado por el ruler de Loki.

```
# Reglas de correlación y alerta del SIEM (Loki ruler, LogQL). Fase 6.
# Cada regla se asocia a un riesgo del registro (docs/fase-6/tratamiento-riesgo.md) y a OWASP Top 10:2025.
# Ventanas cortas (5 min) para el laboratorio; en producción se ajustarían umbrales y supresión.
groups:
  - name: juice-shop-seguridad
    interval: 15s
    rules:
      - alert: WAF_InyeccionSQL_Bloqueada
        expr: sum(count_over_time({job="waf_audit"} |= "\"ruleId\":\"942" [5m])) > 0
        labels: {severity: high, owasp: "A05:2025", riesgo: "R01,R02", fuente: waf}
        annotations:
          summary: "El WAF bloqueó intentos de inyección SQL (familia CRS 942xxx)"


      - alert: WAF_ParcheVirtual_Activado
        expr: sum(count_over_time({job="waf_audit"} |~ "\"ruleId\":\"10000[0-9]\"" [5m])) > 0
        labels: {severity: high, owasp: "A01/A02:2025", riesgo: "R07,R17", fuente: waf}
        annotations:
          summary: "Se activó un parche virtual propio (100001 asignación masiva / 100002 /metrics)"


      - alert: Login_FuerzaBruta_RateLimit
        expr: sum(count_over_time({job="waf_access", status="429"} [5m])) >= 3
        labels: {severity: medium, owasp: "A07:2025", riesgo: "R16", fuente: waf}
        annotations:
          summary: "Ráfaga de intentos de login frenada por limitación de tasa (HTTP 429)"


      - alert: Acceso_Rutas_Sensibles_Denegado
```

```
        expr: sum(count_over_time({job="waf_access", status="403"} | json | uri=~"/(ftp|encryptionkeys|metrics|
support/logs).*" [5m])) > 0
        labels: {severity: medium, owasp: "A02:2025", riesgo: "R12,R17", fuente: waf}
        annotations:
          summary: "Intentos de acceso a rutas sensibles bloqueadas (listados, /metrics, claves)"


      - alert: API_Enumeracion_Objetos_PosibleBOLA
        expr: count(sum by (uri) (count_over_time({job="waf_access", status="200"} | json |
uri=~"/rest/basket/[0-9]+" [5m]))) >= 2
        labels: {severity: high, owasp: "A01:2025 / API1:2023", riesgo: "R06", fuente: api-monitoring}
        annotations:
          summary: "Acceso a varias cestas distintas en 5 min (patrón de enumeración / BOLA)"


      - alert: RASP_Ataque_Detectado
        expr: sum(count_over_time({job="docker", container="juice-hardened"} |~ "^Zen has (blocked|detected)"
[5m])) > 0
        labels: {severity: critical, owasp: "A05:2025", riesgo: "R01,R02", fuente: rasp}
        annotations:
          summary: "El RASP (Aikido Zen) detectó o bloqueó un ataque dentro de la aplicación"


      - alert: App_Errores_5xx
        expr: sum(count_over_time({job="waf_access"} | json | status=~"5.." [5m])) > 5
        labels: {severity: medium, owasp: "A10:2025", riesgo: "R18", fuente: api-monitoring}
        annotations:
          summary: "Tasa anómala de errores 5xx (posibles condiciones excepcionales mal gestionadas)"
```

Anexo D. Controles por riesgo: implementación, verificación y evidencia

R01 — Inyección SQL en el login (bypass de autenticación)

- WAF ModSecurity + CRS 942100/949110 (HTTP 403) *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/http.tsv`
- RASP Aikido Zen + integración rasp-guard: bloqueo en sqlite3.all con HTTP 403 *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/http.tsv`
- Alertas SIEM WAF_InyeccionSQL_Bloqueada y RASP_Ataque_Detectado *[detectivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03b-rasp-a-siem/alertas.json`
- Parche 01: consulta parametrizada *[eliminacion; Sin verificar]* `app-hardened/patches/01-sqli-login.patch`

R02 — Inyección SQL UNION en búsqueda (extracción de tablas)

- WAF ModSecurity + CRS 942xxx (HTTP 403) *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/http.tsv`
- RASP Aikido Zen + rasp-guard: bloqueo en sqlite3.all (query.q) con HTTP 403 *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/http.tsv`
- Alertas SIEM de inyección (WAF y RASP) *[detectivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03b-rasp-a-siem/alertas.json`
- Parche 02: consulta parametrizada *[eliminacion; Sin verificar]* `app-hardened/patches/02-sqli-search.patch`

R03 — Clave privada JWT embebida en el código (forja de tokens)

- Parche 04: clave privada fuera del código (variable/secreto) *[eliminacion; Sin verificar]* `app-hardened/patches/04-clave-privada-embebida.patch`
- Gestor de secretos / KMS del proveedor cloud (custodia compartida, no transfiere la responsabilidad) *[transferencia; Sin verificar]* `infra/terraform/`

  Nota: El endpoint /encryptionkeys/jwt.pub sirve la clave PÚBLICA: no es una vulnerabilidad y su bloqueo no reduce este riesgo.

R04 — Bibliotecas JWT obsoletas (algoritmos débiles)

- SCA en CI (npm audit, OSV, Grype) que identifica el componente *[detectivo; Probado]* `evidence/fase-3/sca/`
- Actualizar bibliotecas JWT y fijar algoritmos *[eliminacion; Sin verificar]* `docs/fase-1/fase1-modelado-amenazas.md`

R05 — Contraseñas con MD5 sin sal

- Bloqueo de la vía de extracción por SQLi (WAF + RASP) *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/http.tsv`
- Parche 03: bcrypt (factor 12) *[eliminacion; Sin verificar]* `app-hardened/patches/03-md5-a-bcrypt.patch`

R06 — BOLA/IDOR: lectura de recursos de otro usuario

• WAF: no bloquea la lectura cruzada (A12 HTTP 200 a través del WAF) *[preventivo; No efectivo]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/bola/resultado-bola.md`

• Heurística SIEM API_Enumeracion_Objetos_PosibleBOLA (con falsos positivos demostrados) *[detectivo; Probado]* `evidence/fase-6/validacion-2026-11-10/04-falsos-positivos/alertas-tras-trafico-legitimo.json`

• Parche 08: verificación de propietario (403) *[eliminacion; Sin verificar]* `app-hardened/patches/08-bola-cesta-propietario.patch`

R07 — Asignación masiva de role=admin en el registro

• Parche virtual ModSecurity 100001 (HTTP 403) *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/http.tsv`

• Alerta SIEM WAF_ParcheVirtual_Activado *[detectivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/reglas-estado.json`

• Parche 06: lista blanca de campos *[eliminacion; Sin verificar]* `app-hardened/patches/06-asignacion-masiva-registro.patch`

R08 — Inyección NoSQL en reseñas (MarsDB)

• Rechazar operadores en filtros de MarsDB *[eliminacion; Sin verificar]* `docs/fase-1/fase1-modelado-amenazas.md`

R09 — Ejecución de código vía eval()/vm

• Contención: FS raíz de solo lectura (escritura bloqueada con EROFS), usuario no root, cap_drop ALL *[contencion; Probado]* `evidence/fase-5/despues/runtime-hardening-inspect.txt`

• Parche 05: eliminar eval() *[eliminacion; Sin verificar]* `app-hardened/patches/05-eval-userprofile.patch`

R10 — XXE en la carga de XML

• Parser XML sin entidades externas ni DTD *[eliminacion; Sin verificar]* `app-hardened/patches/README.md`

R11 — SSRF en la imagen de perfil por URL

• Lista blanca de destinos y filtrado de egreso *[preventivo; Sin verificar]* `app-hardened/patches/README.md`

R12 — Listado de directorios y archivos internos (/ftp, /support/logs, /encryptionkeys)

• nginx deny de rutas sensibles (HTTP 403) *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/http.tsv`

• Alerta SIEM Acceso_Rutas_Sensibles_Denegado *[detectivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/reglas-estado.json`

• Retirar serve-index y archivos internos (Evitar) *[evitacion; Sin verificar]* `app-hardened/patches/README.md`

Nota: En /encryptionkeys el problema es el LISTADO del directorio; la clave pública que contiene no es una vulnerabilidad.

R13 — XSS (CSP débil, sin codificación de salida)

• CSP (script-src 'self') y cabeceras en el WAF: presentes en la respuesta *[preventivo; Inspeccionado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/a9-security-headers.txt`

• CRS 941 (XSS) cargado, sin eventos observados *[preventivo; Inspeccionado]* `evidence/fase-6/waf/crs-inventario.txt`

• Codificación de salida en el frontend *[eliminacion; Sin verificar]* `docs/fase-1/fase1-modelado-amenazas.md`

R14 — CORS permisivo (ACAO *)

• WAF oculta Access-Control-Allow-Origin (comprobado con Origin externo) *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/a8-cors-headers.txt`

• Parche 07: origen explícito *[eliminacion; Sin verificar]* `app-hardened/patches/07-cors-restringido.patch`

R15 — Redirección abierta (lista blanca evadible)

• Comparación exacta de destinos permitidos *[eliminacion; Sin verificar]* `docs/fase-1/fase1-modelado-amenazas.md`

R16 — Fuerza bruta en el login (sin limitación de intentos)

• Rate limiting nginx 5/min por IP, ráfaga 3 (HTTP 429) *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/a10-bruteforce-login.txt`

• Alerta SIEM Login_FuerzaBruta_RateLimit *[detectivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/reglas-estado.json`

R17 — /metrics expuesto sin autenticación

• nginx deny /metrics + parche virtual 100002 (mismo componente WAF) *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/a6-metrics.txt`

• Alerta SIEM Acceso_Rutas_Sensibles_Denegado *[detectivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/reglas-estado.json`

R18 — Denegación de servicio por vm/ZIP (agotamiento de recursos)

• Límites de pids (200), memoria (1 GiB) y CPU (1.0) configurados *[contencion; Inspeccionado]* `evidence/fase-5/despues/runtime-hardening-inspect.txt`

R19 — Registro sin centralización ni alertas

• SIEM: Alloy -> Loki -> Grafana; 3 fuentes ingestadas y 7 reglas (6 disparadas en las pruebas) *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03b-rasp-a-siem/alertas.json`

R20 — Dependencias con CVE críticas (cadena de suministro)

• SCA en CI (npm audit, OSV, Grype, Trivy) en cada push *[detectivo; Probado]* `evidence/fase-3/sca/`

• Actualizar dependencias vulnerables *[eliminacion; Sin verificar]* `docs/fase-5/fase5-contenedores-hardening.md`

R21 — Configuración insegura al desplegar la arquitectura cloud (AWS)

• No desplegar sin aprobación (sin terraform apply, sin .tfstate, sin credenciales AWS) *[evitacion; Probado]* `evidence/fase-6/validacion-2026-11-10/06-cloud-no-desplegado.txt`

• Checkov sobre Terraform (144 passed / 0 failed): verificación ESTÁTICA *[preventivo; Inspeccionado]* `evidence/fase-2/checkov-final/`

• Servicios gestionados (AWS WAFv2, KMS) y responsabilidad compartida *[transferencia; Sin verificar]* `infra/terraform/`

Nota: El residual Bajo vale solo mientras no se despliegue; al desplegar, el riesgo vuelve a su valor inherente (12) hasta probar la seguridad en ejecución.

R22 — Bloqueo del RASP que deja peticiones colgadas o termina el proceso (auto-DoS)

• Integración rasp-guard: el bloqueo en sqlite3 se entrega como error controlado HTTP 403 (sin --unhandled-rejections=warn) *[eliminacion; Probado]* `evidence/fase-6/validacion-2026-11-10/02d-rasp-bloqueo-integrado/estado-contenedor.txt`

• --unhandled-rejections=warn: evita la caída pero deja la petición sin respuesta (000 tras 20 s); descartado *[contencion; No efectivo]* `evidence/fase-6/validacion-2026-11-10/02c-rasp-bloqueo-warn/http.tsv`

Nota: La respuesta 403 la genera el manejador de errores de Juice Shop, que muestra una traza de pila (comportamiento preexistente, A10).

R23 — Exposición de datos personales (incumplimiento de protección de datos)

• Bloqueo de la extracción masiva por SQLi (WAF + RASP) *[preventivo; Probado]* `evidence/fase-6/validacion-2026-11-10/03-waf-rasp-siem/http.tsv`

• Póliza de ciberriesgo / cláusulas contractuales (no transfiere la responsabilidad legal del titular) *[transferencia; Sin verificar]* `docs/fase-6/tratamiento-riesgo.md`

R24 — SIEM del laboratorio: privilegio sobre Docker, un solo nodo, Loki sin autenticación

• Proxy del socket de Docker de solo lectura (escrituras HTTP 403); Alloy sin root, sin socket, sin capacidades *[contencion; Probado]* `evidence/fase-6/validacion-2026-11-10/05-siem-seguridad/proxy-socket-api.txt`

• Loki y Grafana publicados solo en 127.0.0.1 *[preventivo; Inspeccionado]* `deploy/hardened/docker-compose.ops.yml`

Anexo E. Validación automática del registro de riesgos

Resumen de `docs/fase-6/datos/validacion-consistencia.txt`: 301 comprobaciones superadas y 0 fallas. Prueba negativa (`prueba-negativa-validador.txt`): al forzar sobre una copia una reducción de P en R13 (CSP solo

inspeccionada) y de I en R04 (SCA, control detectivo), el validador termina con código 1 y señala ambas reglas.